# 🌐 Module 13: IoT Penetration Testing

```
# Exercise 01: Performing IOT Firmware Acquisition, Extraction, Analysis, and Emulation
```

## Scenario

**IoT Firmware Analysis & QEMU Emulation** is a fundamental penetration testing phase used to analyze embedded firmware images, extract root filesystems, identify hardcoded secrets and unvalidated web interfaces, and emulate full system architectures using tools like **Binwalk**, **Firmadyne**, and **QEMU**.

Key technical phases in IoT firmware security auditing:
1. **Signature Identification & Extraction**: Inspecting binary signatures with **hexdump -c firmware.bin** (discovering `qshs` Squashfs magic bytes) and extracting filesystems using **binwalk -e firmware.bin**.
2. **Static Source Code Auditing**: Navigating the extracted **squashfs-root** Linux filesystem ( `/home/www/` ), inspecting PHP web pages (**boardDataWW.php**), and identifying unvalidated user inputs vulnerable to Command Injection.
3. **Automated Emulation via Firmadyne**:
- Configuring **firmadyne.config** paths ( `FIRMWARE_DIR` ).
- Extracting tarball filesystems into PostgreSQL: **python3 sources/extractor/extractor.py -b Netgear -sql 127.0.0.1 -np -nk "WNAP320 Firmware Version 2.0.3.zip" images**.
- Determining target CPU architecture: **bash scripts/getArch.sh images/1.tar.gz**.
- Populating database schema ( `tar2db.py` ) and creating QEMU raw disk images (**bash scripts/makeImage.sh 1**).
- Inferring network interfaces (**bash scripts/inferNetwork.sh 1**) and launching dynamic emulation (**bash scratch/1/run.sh**).
4. **Dynamic Web & Protocol Enumeration**: Accessing emulated web management interface (**http://192.168.0.100**), performing automated SNMP enumeration ( `snmpwalk.sh` ), Web path discovery ( `webAccess.py` ), and Metasploit automated exploit checks ( `runExploits.py` ).

In this exercise, we log into **Parrot Security** VM (**pentester** / **toor**), analyze Netgear WNAP320 wireless access point firmware **firmware.bin**, extract the **squashfs** root filesystem, inspect insecure PHP source code, configure Firmadyne, build QEMU disk images, emulate the device network stack at **192.168.0.100**, access the running web GUI, and execute automated analysis scripts.

## Objective

The objective of this lab is to help students learn how to:
- Authenticate to Parrot Security target VM (**pentester** / **toor**)
- Inspect Netgear WNAP320 firmware binary signature using file and hexdump: **hexdump -c firmware.bin**
- Extract Squashfs root filesystem using Binwalk: **binwalk -e firmware.bin**
- Audit extracted Linux web root (**_firmware.bin.extracted/squashfs-root/home/www/**)
- Configure Firmadyne framework environment: **firmadyne.config**
- Extract firmware tarball into PostgreSQL database: **sudo python3 sources/extractor/extractor.py -b Netgear -sql 127.0.0.1 -np -nk "WNAP320 Firmware Version 2.0.3.zip" images**
- Identify architecture, populate database, build QEMU disk, and infer network routes ( `192.168.0.100` )
- Execute full QEMU system emulation: **sudo bash scratch/1/run.sh**
- Access emulated web GUI (**http://192.168.0.100**) and vulnerable scripts (**boardDataWW.php**)
- Execute Firmadyne analysis scripts ( `snmpwalk.sh` , `webAccess.py` , `runExploits.py` )
- Identify extracted device filesystem type (**squashfs**)

---

## Task 1: Inspect Firmware Binary, Extract Squashfs Filesystem, Configure Firmadyne, and Emulate Netgear WNAP320

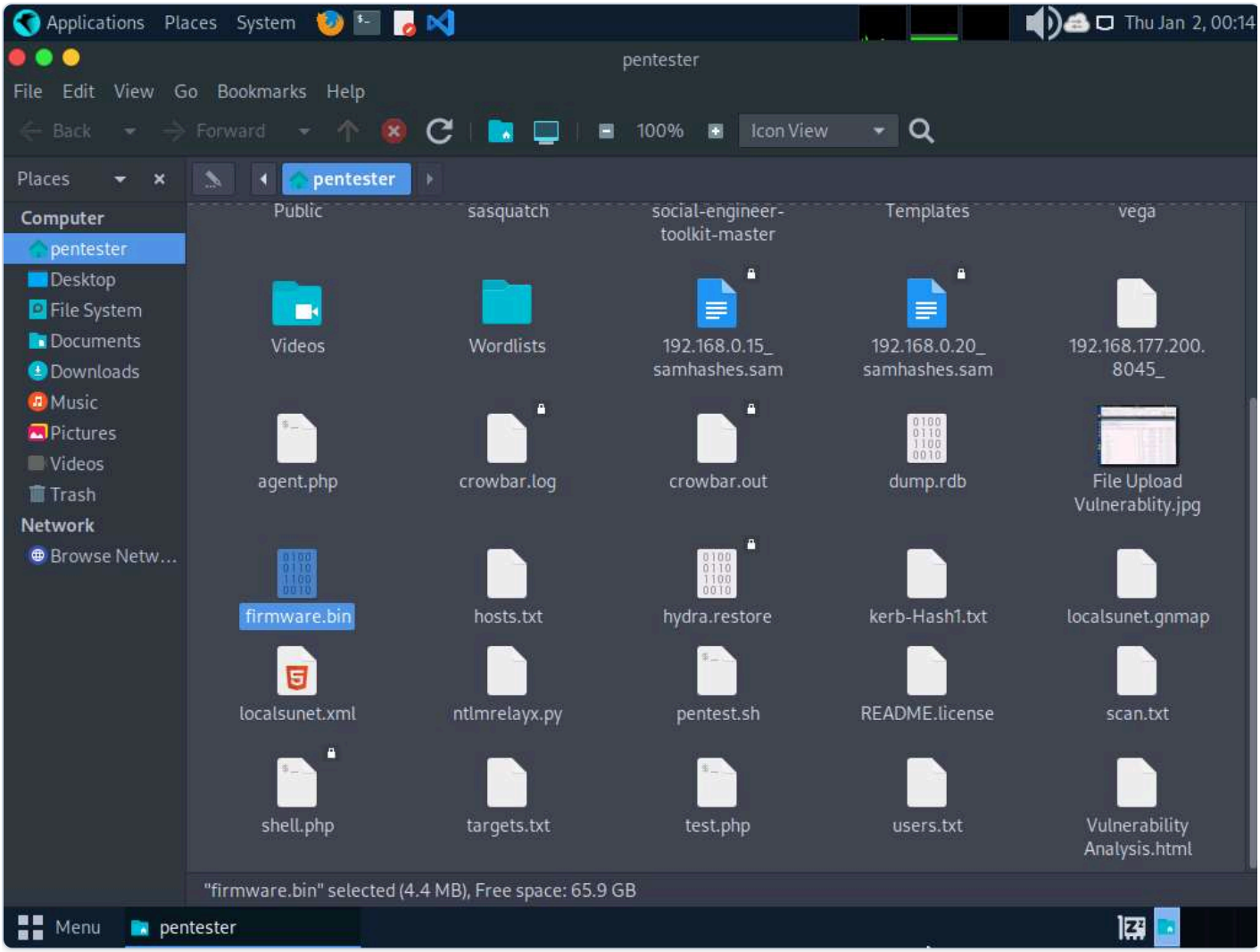
In this task, we analyze `firmware.bin`, extract Squashfs root with `binwalk`, audit `boardDataWW.php`, configure Firmadyne PostgreSQL pipeline, generate QEMU images, run dynamic emulation at `192.168.0.100`, and execute automated Firmadyne security analysis scripts.

### Lab Tasks

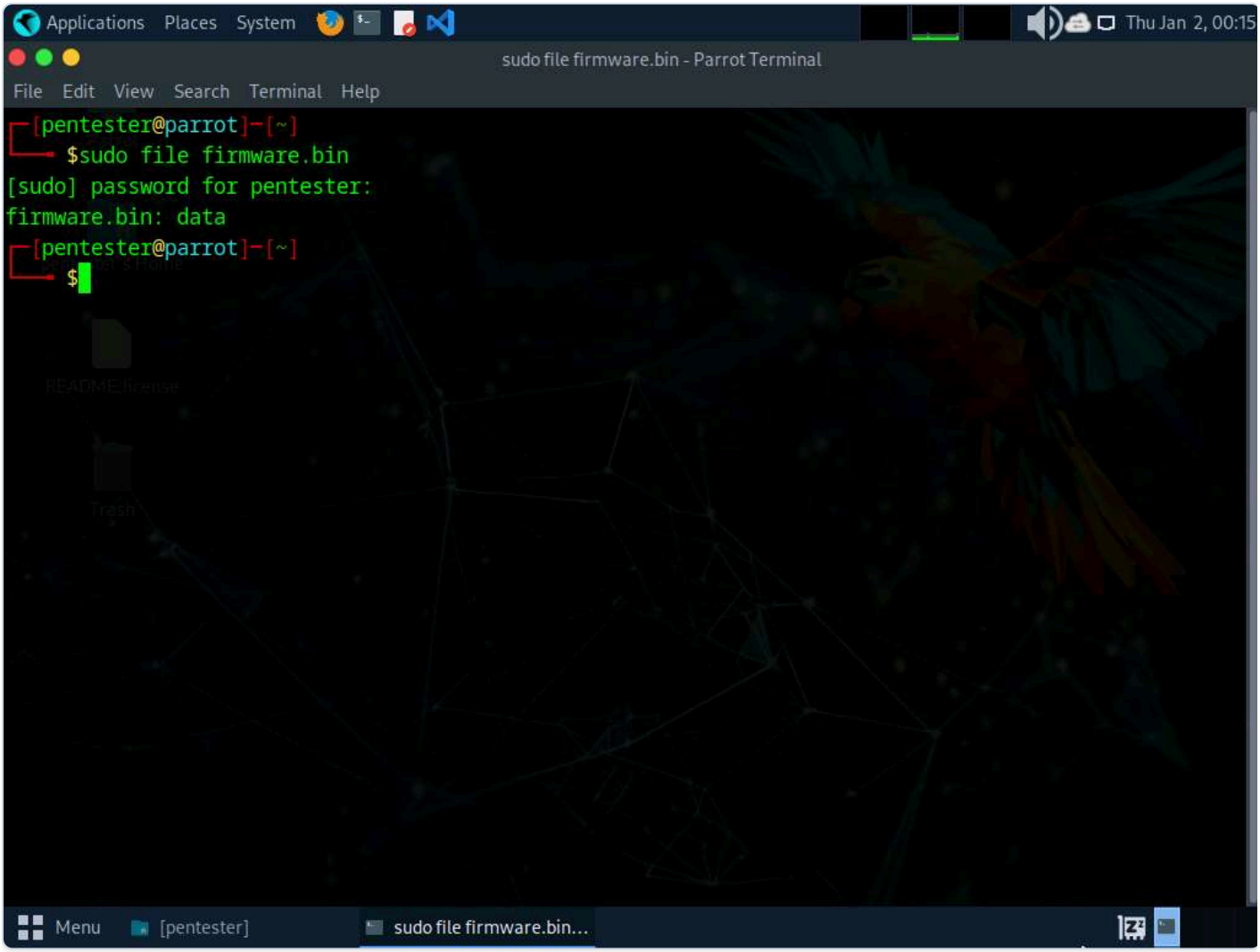
1. Log into **Parrot Security** VM using credentials (**pentester** / **toor**). Netgear WNAP320 hardware reference.



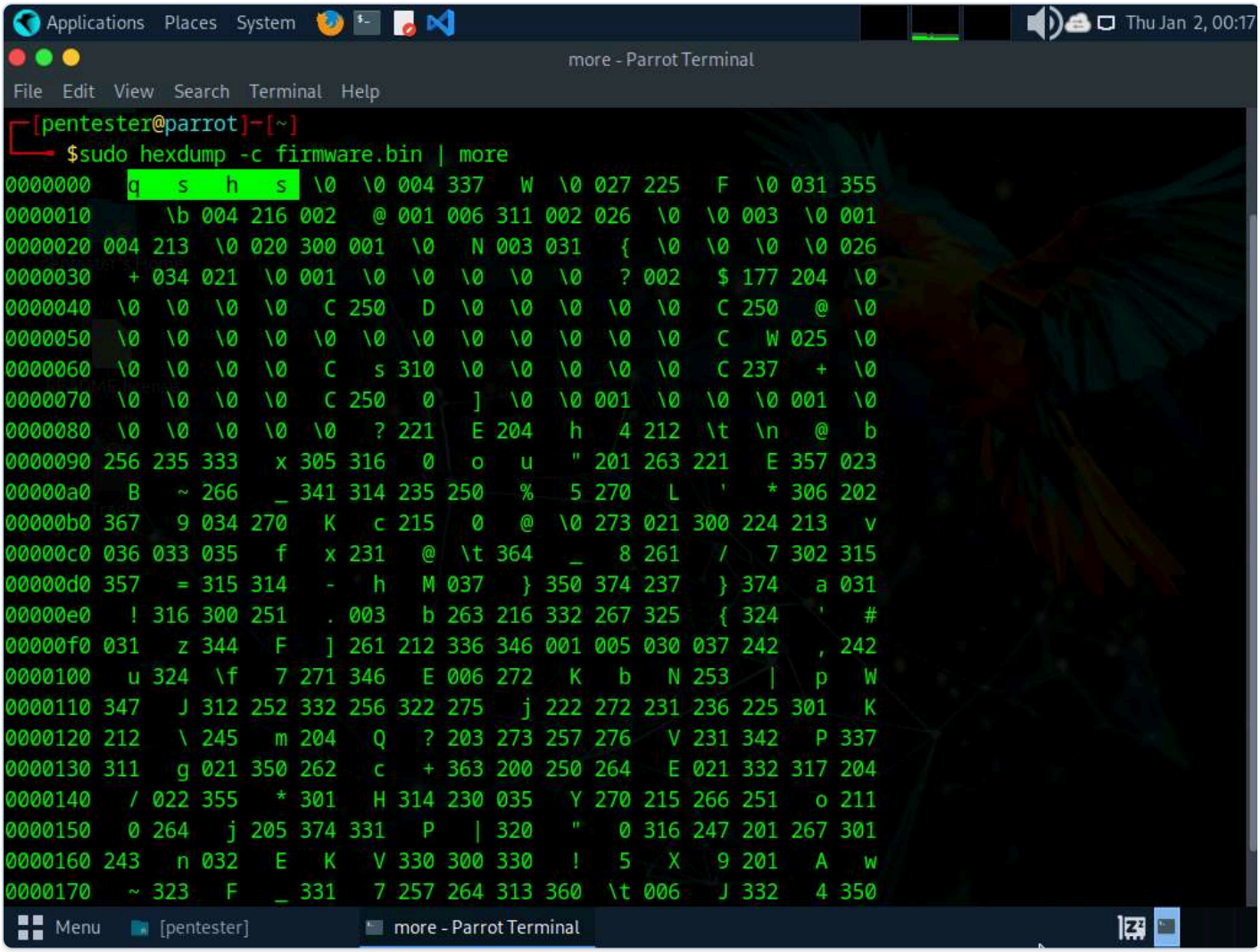
1. Inspect sample firmware binary **firmware.bin** in home directory.



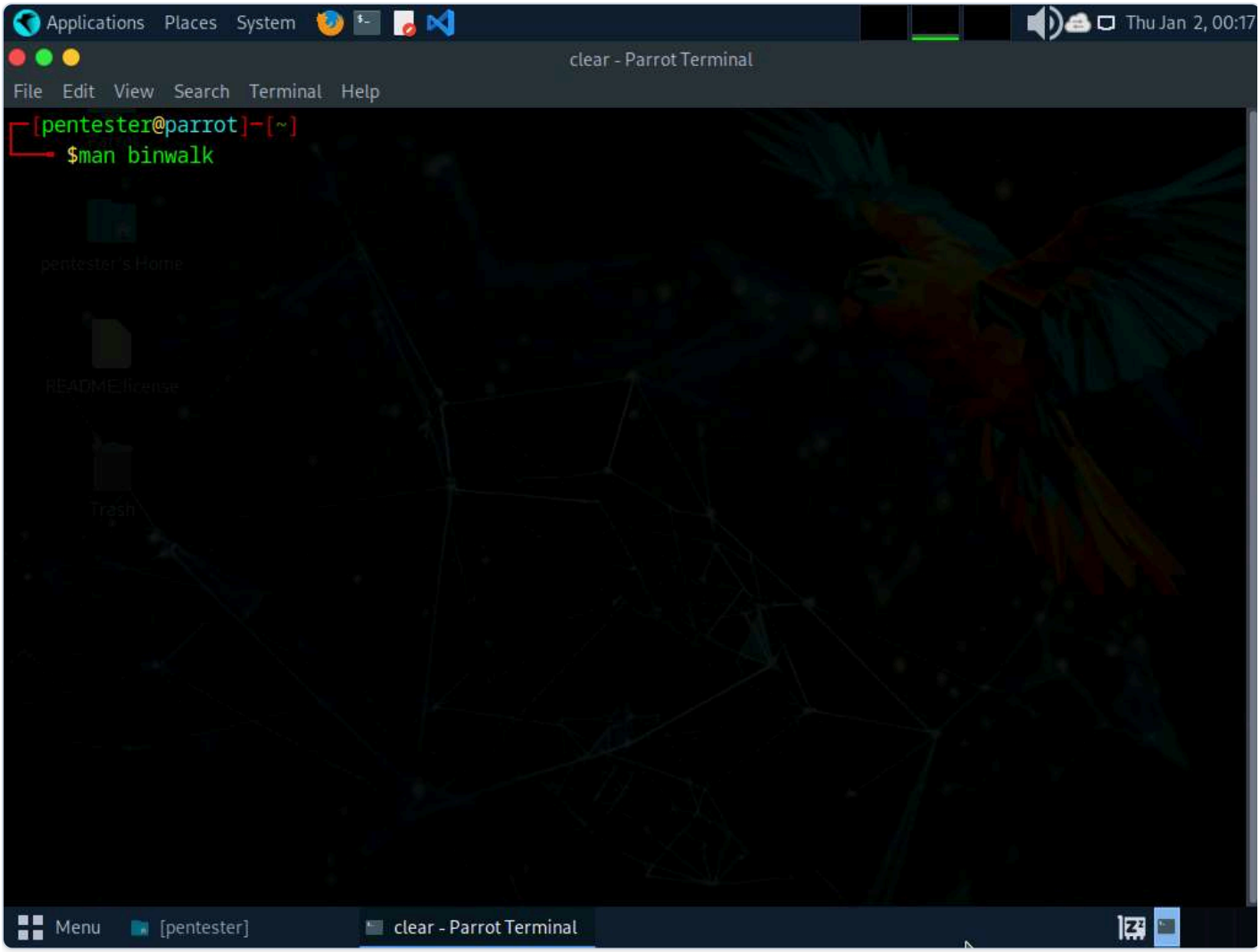

1. Run file command against target binary:
   **sudo file firmware.bin**

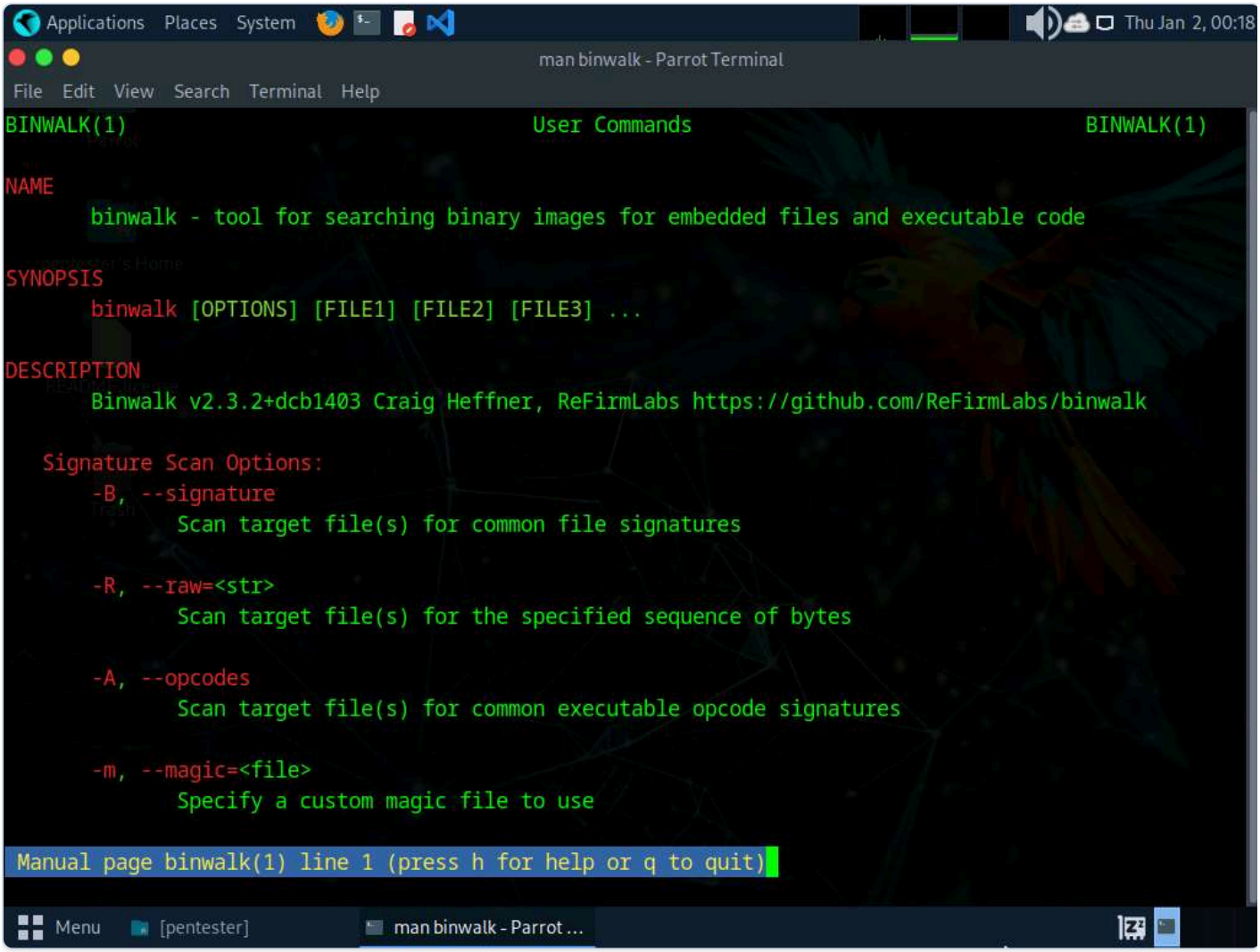



1. Inspect binary header for Squashfs signature ( `qshs` ):
   **sudo hexdump -c firmware.bin | more**

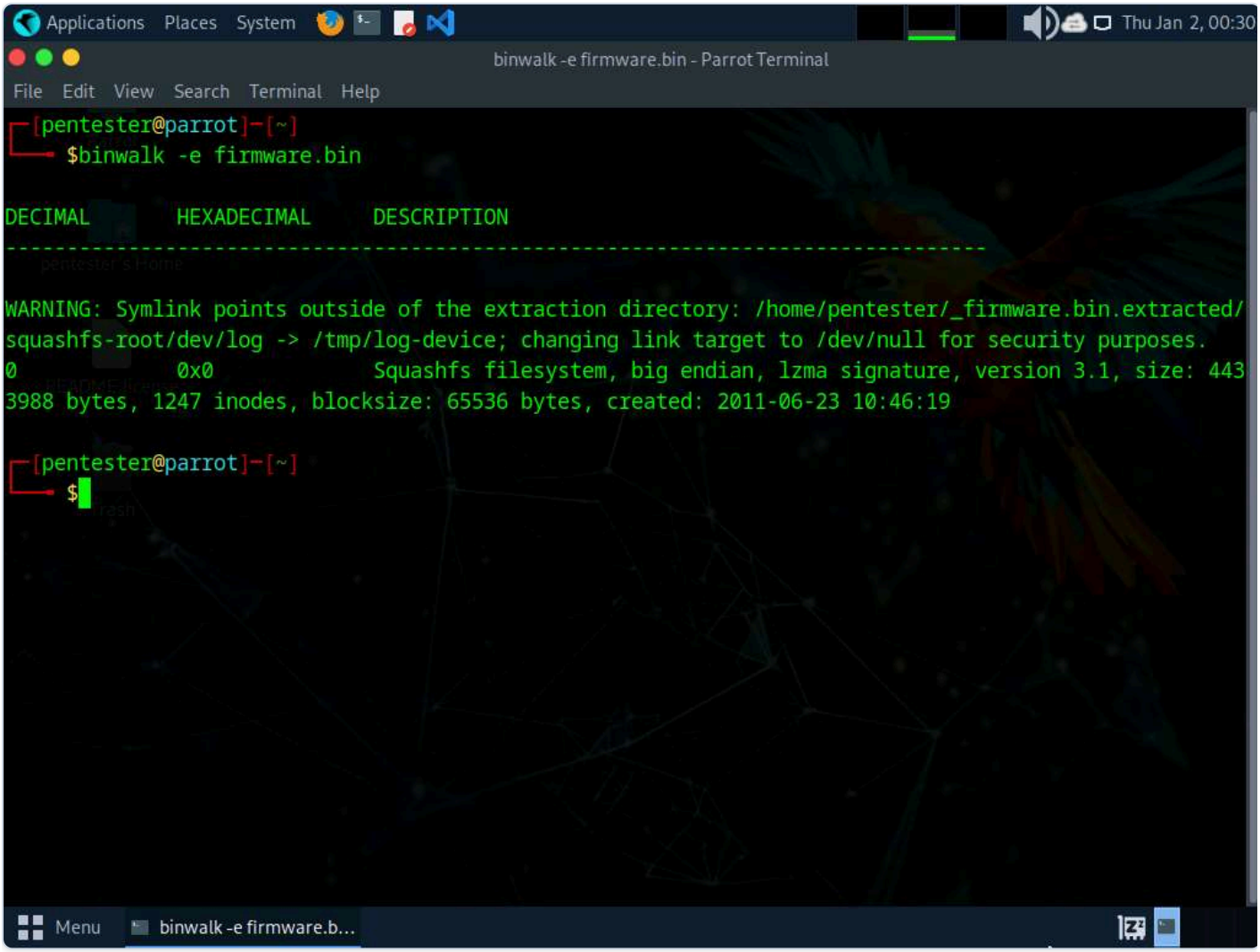


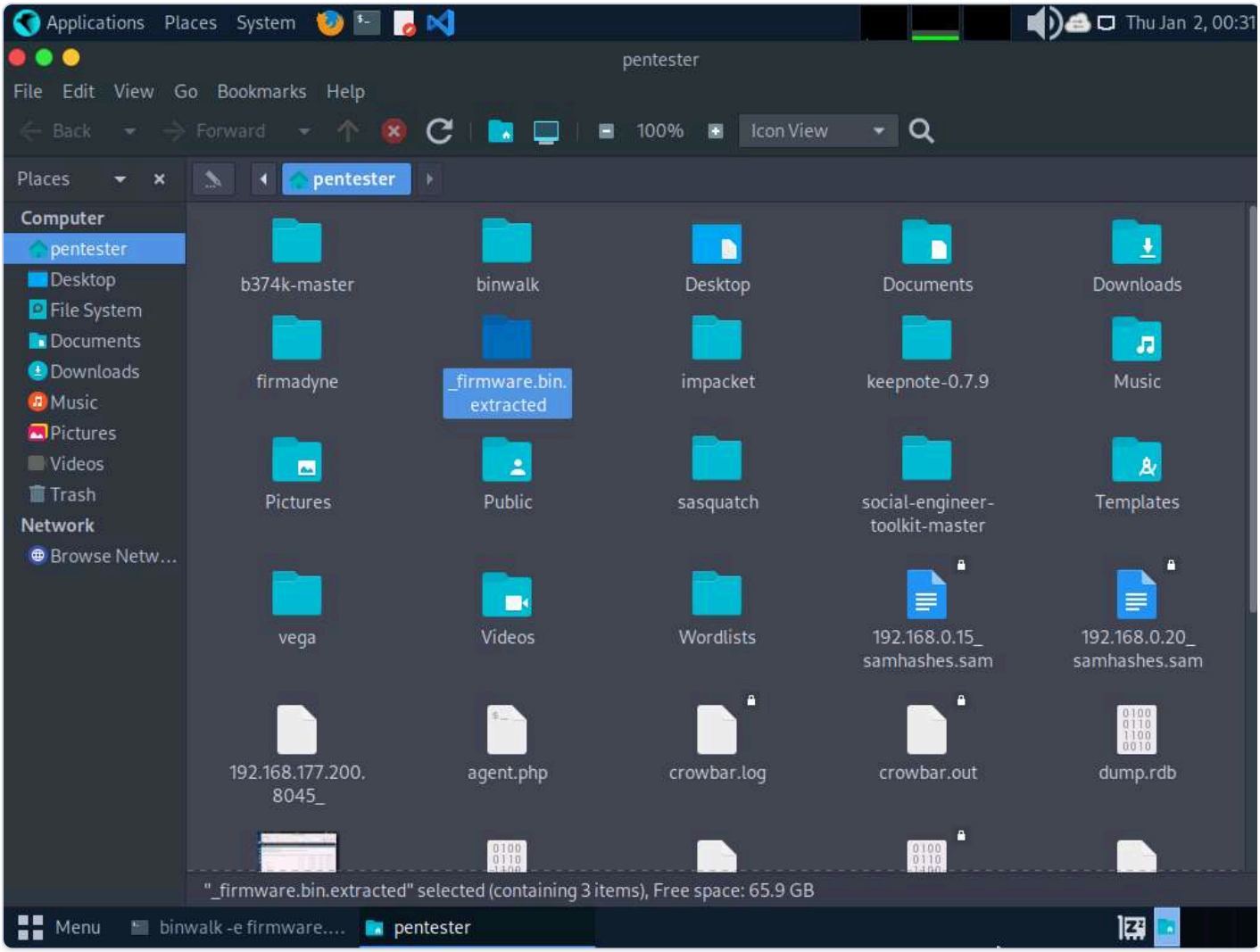

1. Inspect Binwalk documentation manual:
   **man binwalk**


Applications
Places
System
Thu Jan 2, 00:17
clear - Parrot Terminal
File
Edit
View
Search
Terminal
Help
[pentester@parrot]-[~]
$man binwalk
pentester's Home
README.license
Trash
Menu
[pentester]
clear - Parrot Terminal




1. Extract firmware filesystem with Binwalk:
   **binwalk -e firmware.bin**

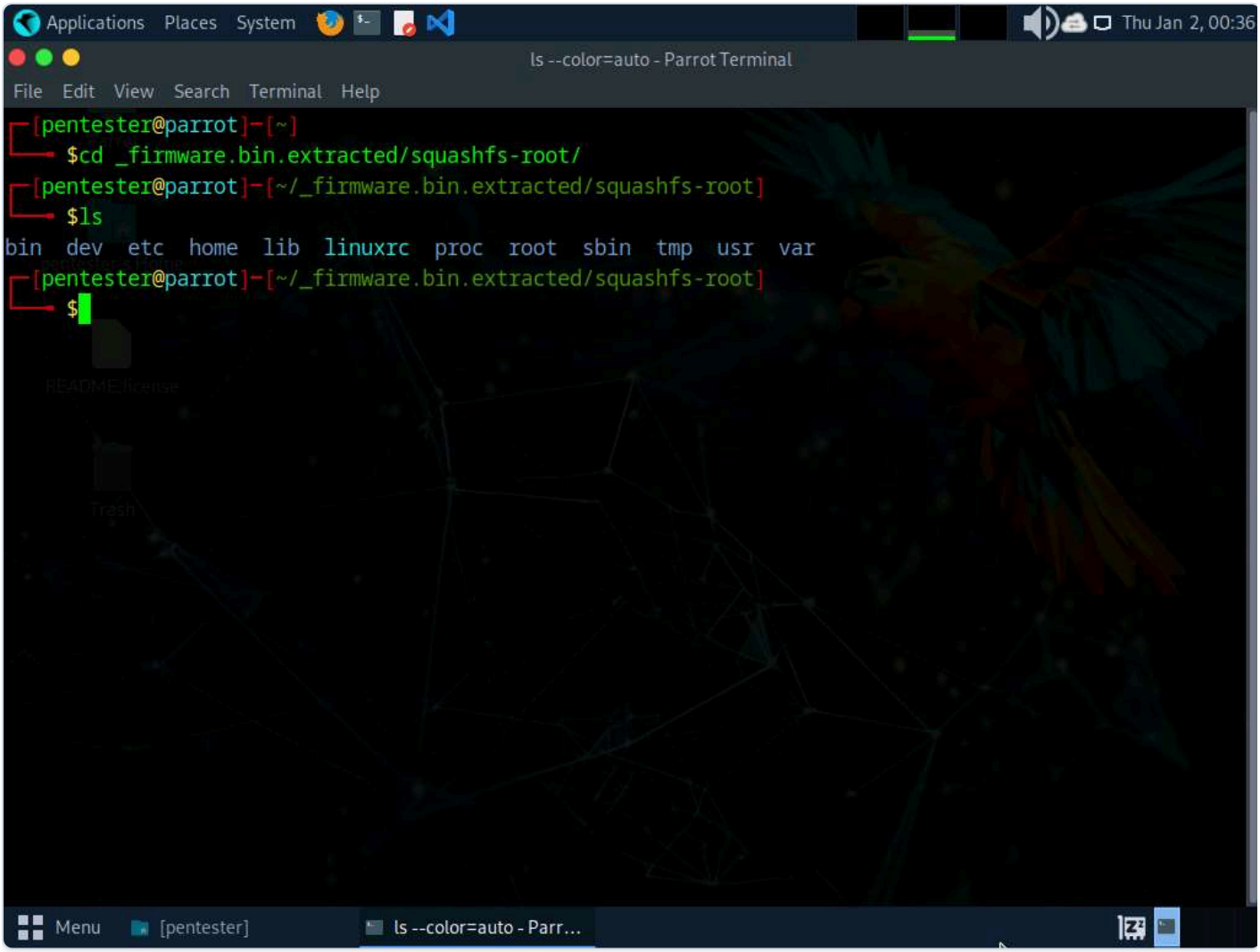

Applications Places System
Thu Jan 2, 00:30
binwalk -e firmware.bin - Parrot Terminal
File Edit View Search Terminal Help
[pentester@parrot]-[~]
$binwalk -e firmware.bin
DECIMAL HEXADECIMAL DESCRIPTION
WARNING: Symlink points outside of the extraction directory: /home/pentester/_firmware.bin.extracted/squashfs-root/dev/log -> /tmp/log-device; changing link target to /dev/null for security purposes.
0 0x0 Squashfs filesystem, big endian, lzma signature, version 3.1, size: 443
3988 bytes, 1247 inodes, blocksize: 65536 bytes, created: 2011-06-23 10:46:19
[pentester@parrot]-[~]
$
Menu
binwalk -e firmware.b...



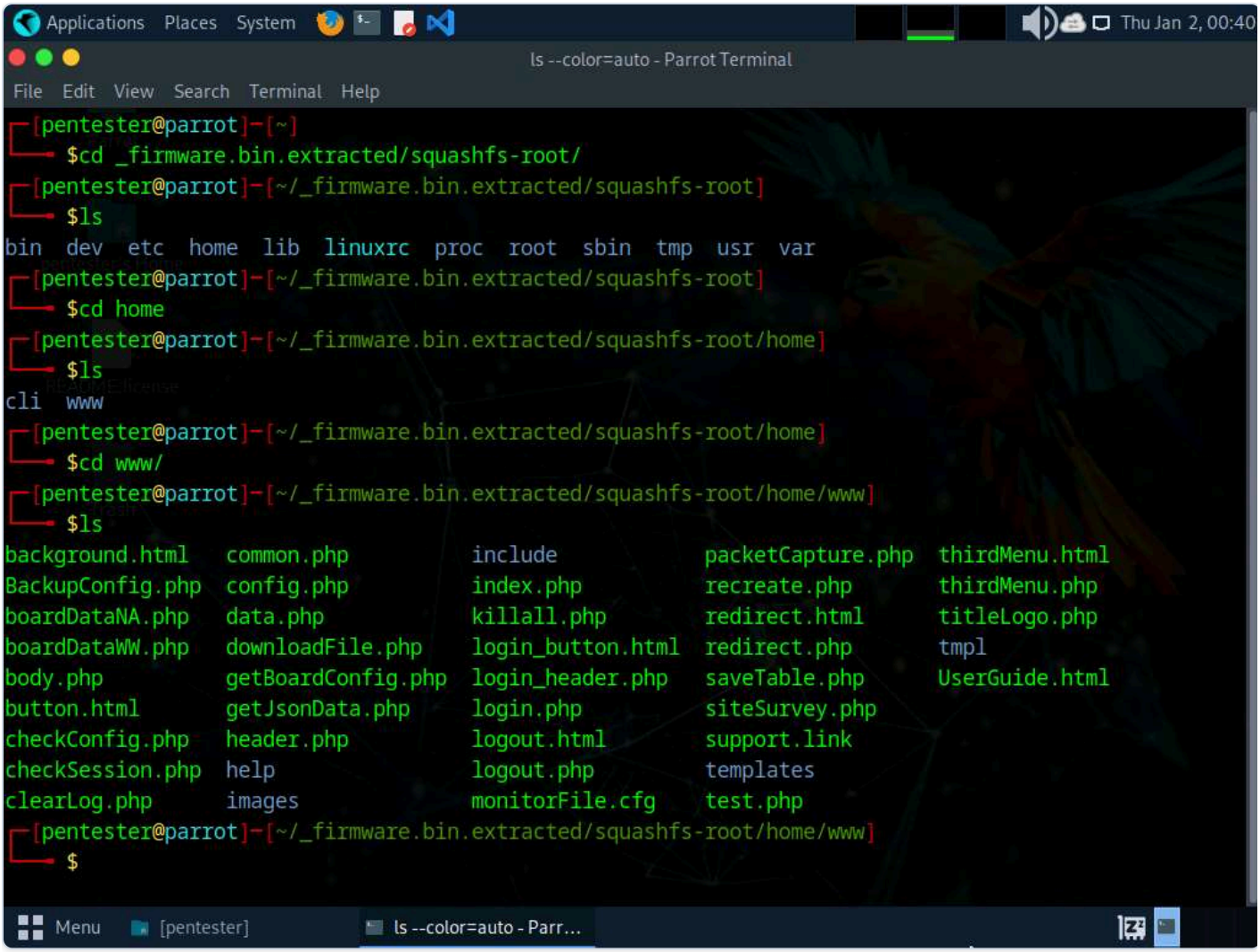

1. Navigate to extracted **squashfs** root filesystem directory:

   **cd _firmware.bin.extracted/squashfs-root**

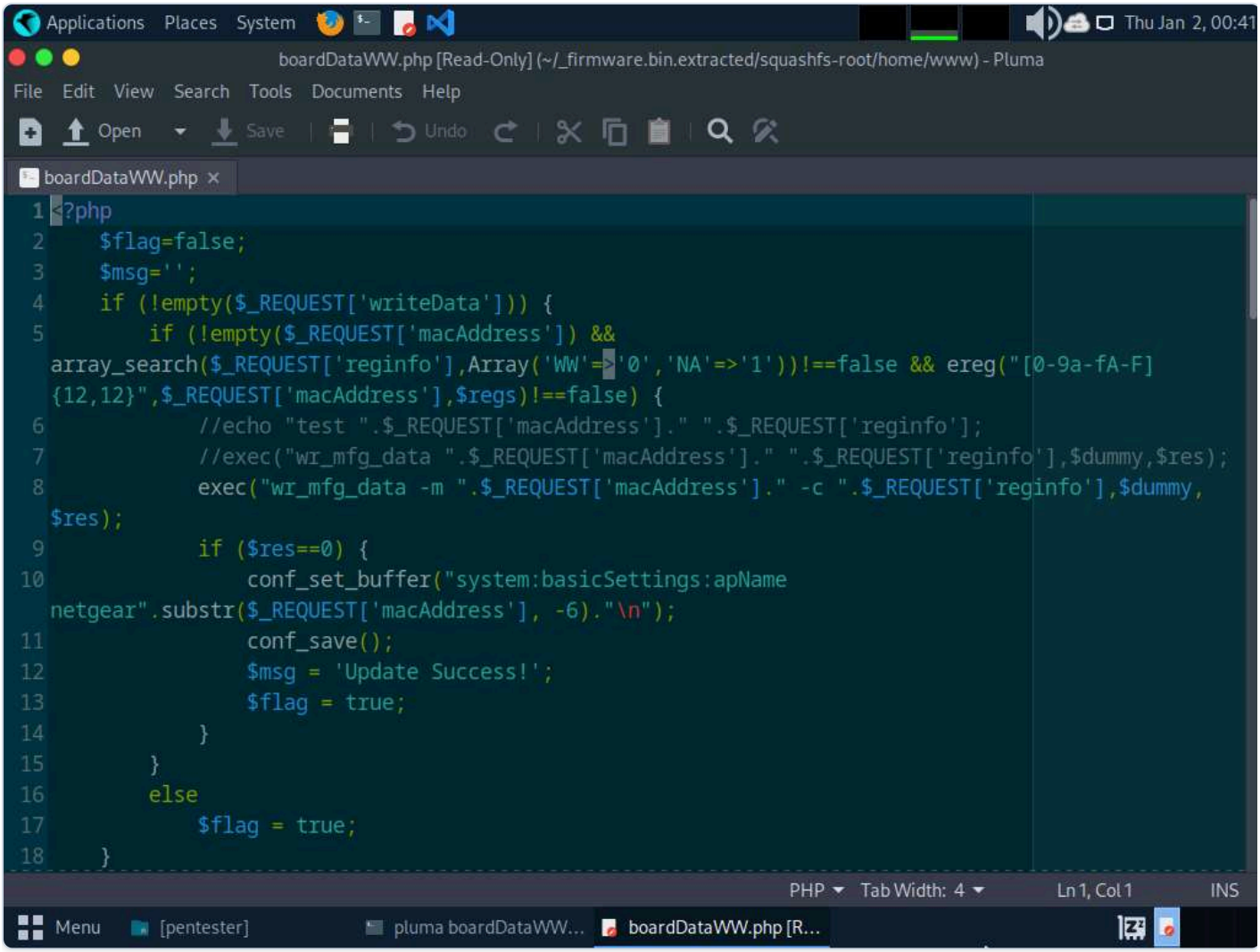
   **ls**



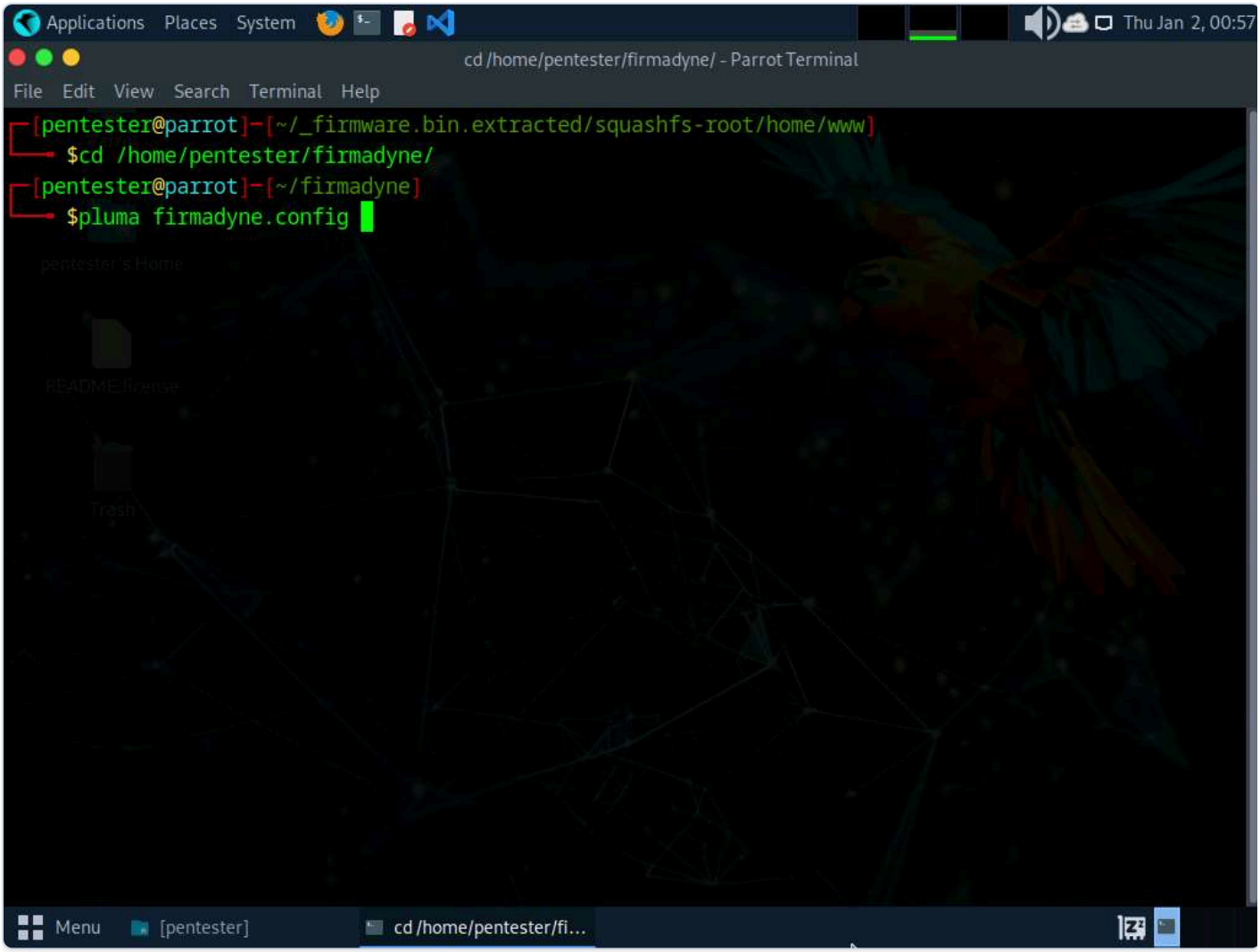

1. Navigate to web server root directory:
   **cd home/www**
   **ls**

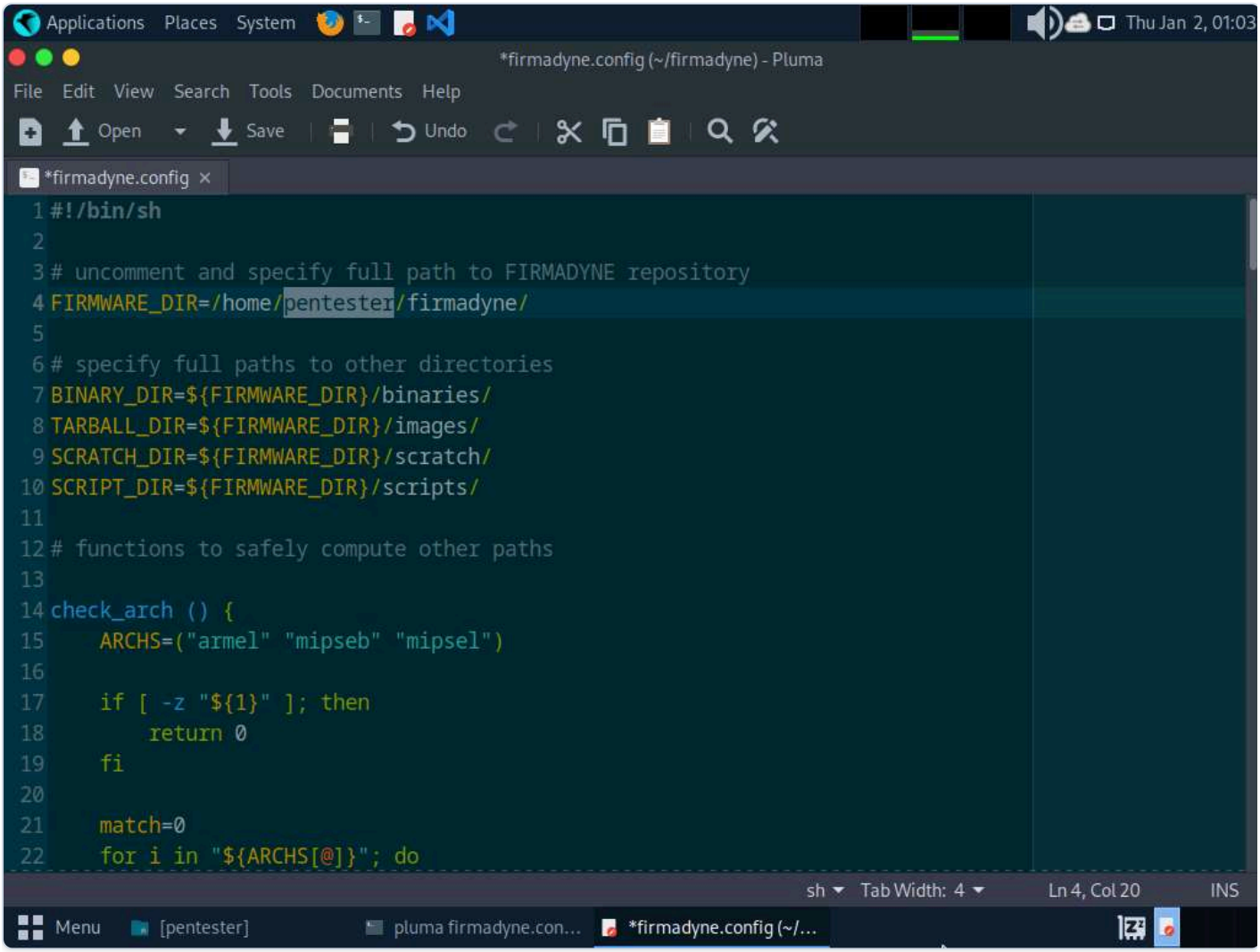



1. Open **boardDataWW.php** in text editor and audit unvalidated input parameters.

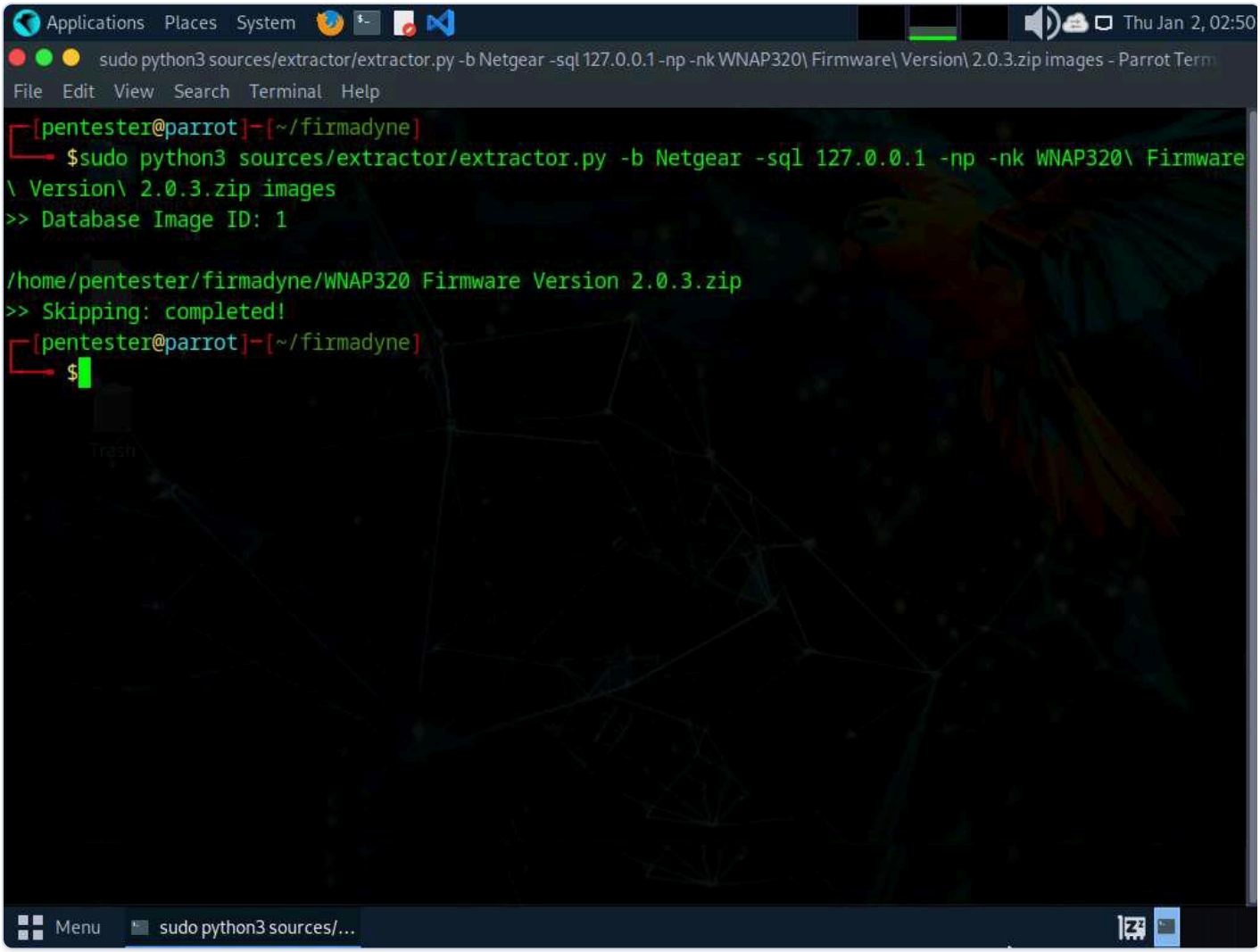



1. Navigate to **firmadyne** directory, edit **firmadyne.config**, set `FIRMWARE_DIR`, and uncomment line.

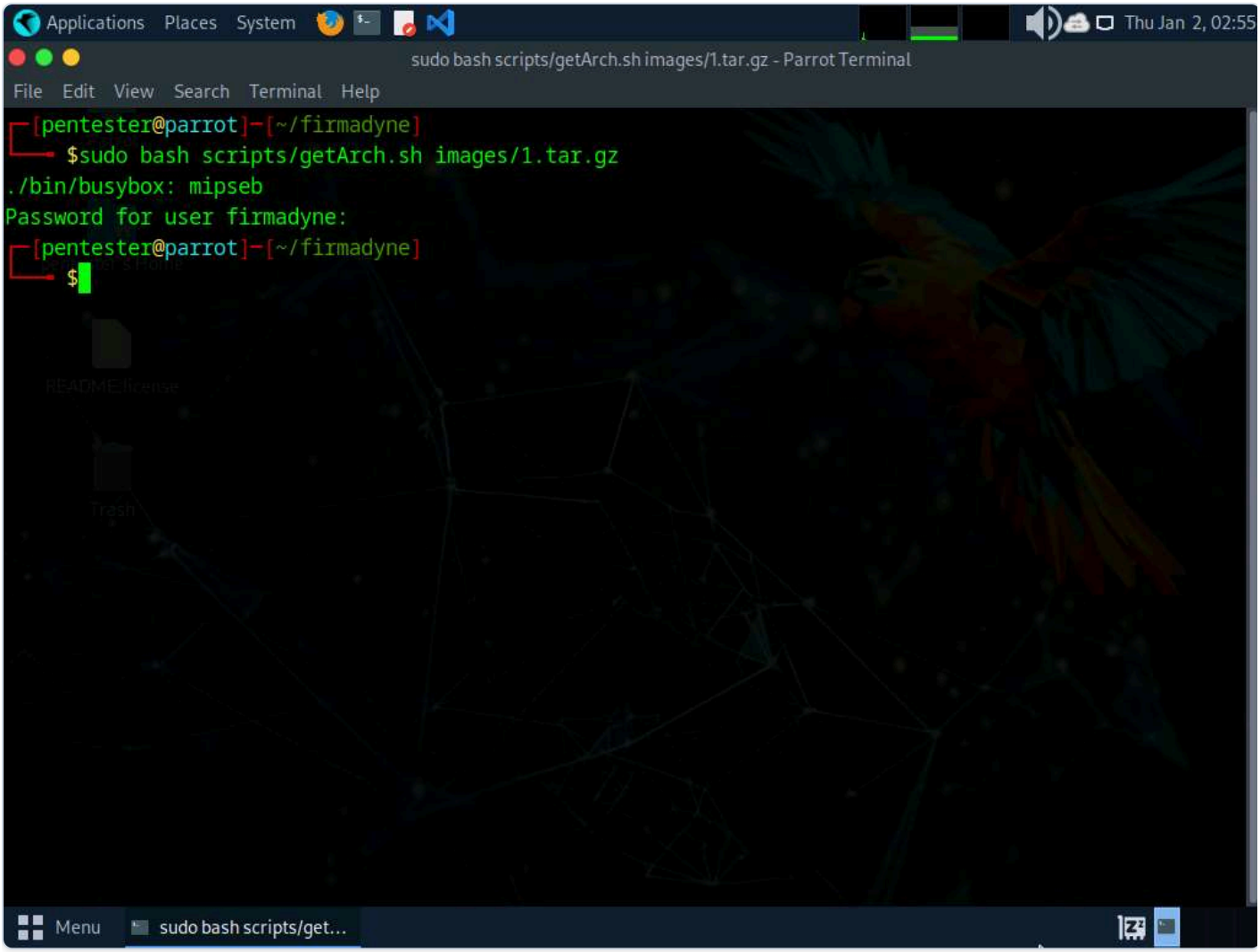

Applications
Places
System
Thu Jan 2, 00:57
cd /home/pentester/firmadyne/ - Parrot Terminal
File
Edit
View
Search
Terminal
Help
[pentester@parrot]-[~/_firmware.bin.extracted/squashfs-root/home/www]
$cd /home/pentester/firmadyne/
[pentester@parrot]-[~/firmadyne]
$pluma firmadyne.config
pentester's Home
README.license
Trash
Menu
[pentester]
cd /home/pentester/fi...



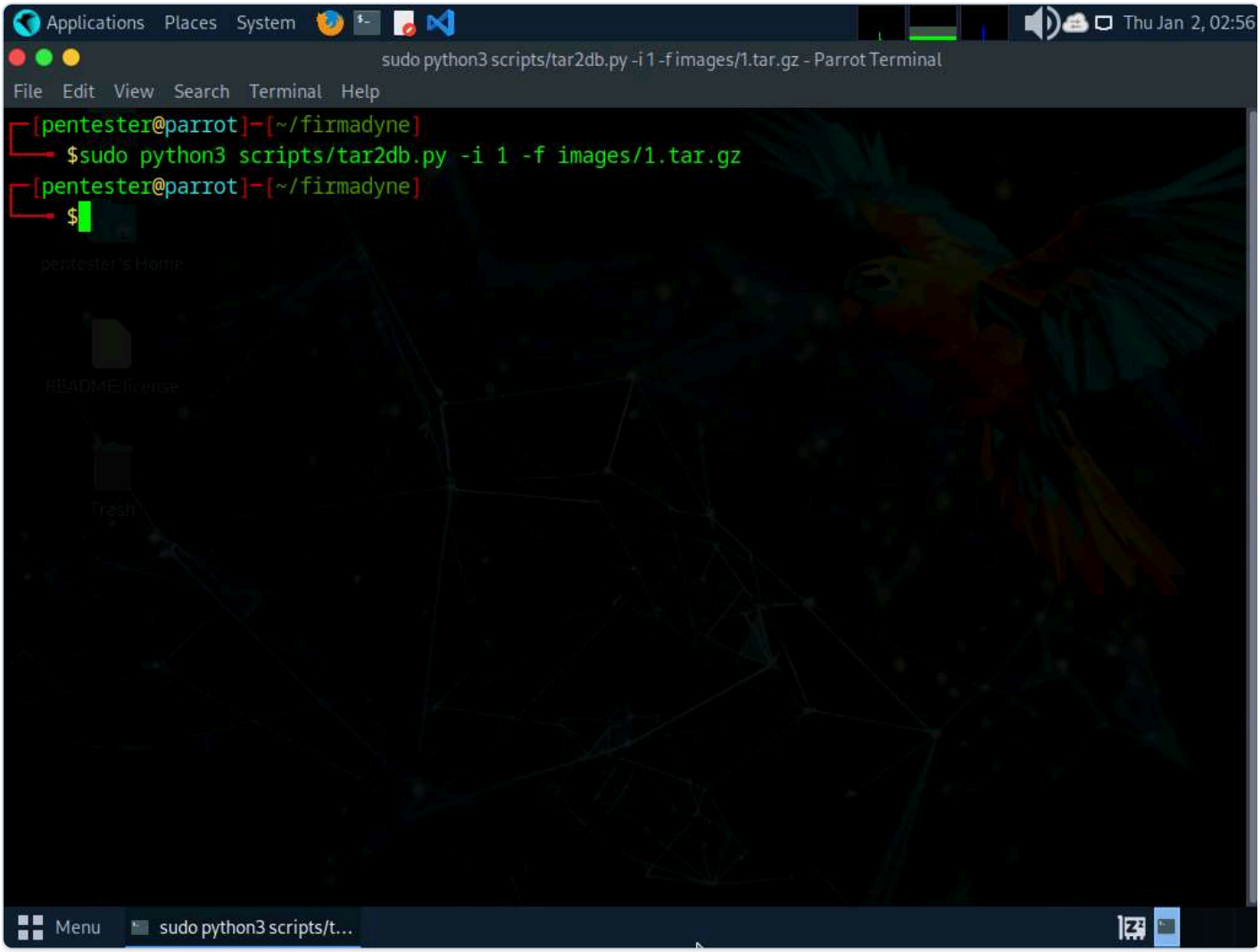

1. Start PostgreSQL service and extract firmware image tarball into database:
   **sudo service postgresql start**
   **sudo python3 sources/extractor/extractor.py -b Netgear -sql 127.0.0.1 -np -nk "WNAP320 Firmware Version 2.0.3.zip" images**



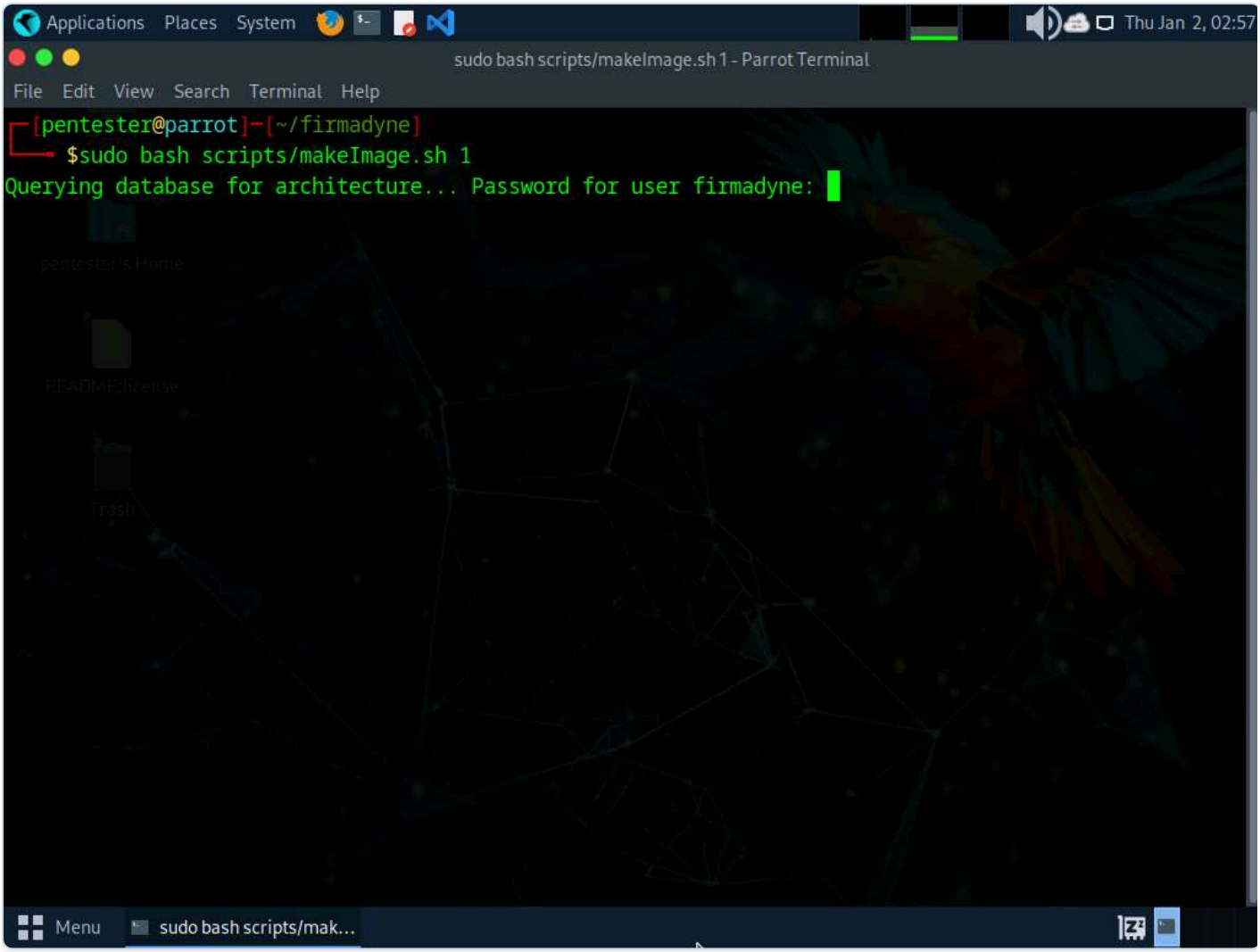

1. Identify firmware CPU architecture:
   **sudo bash scripts/getArch.sh images/1.tar.gz**

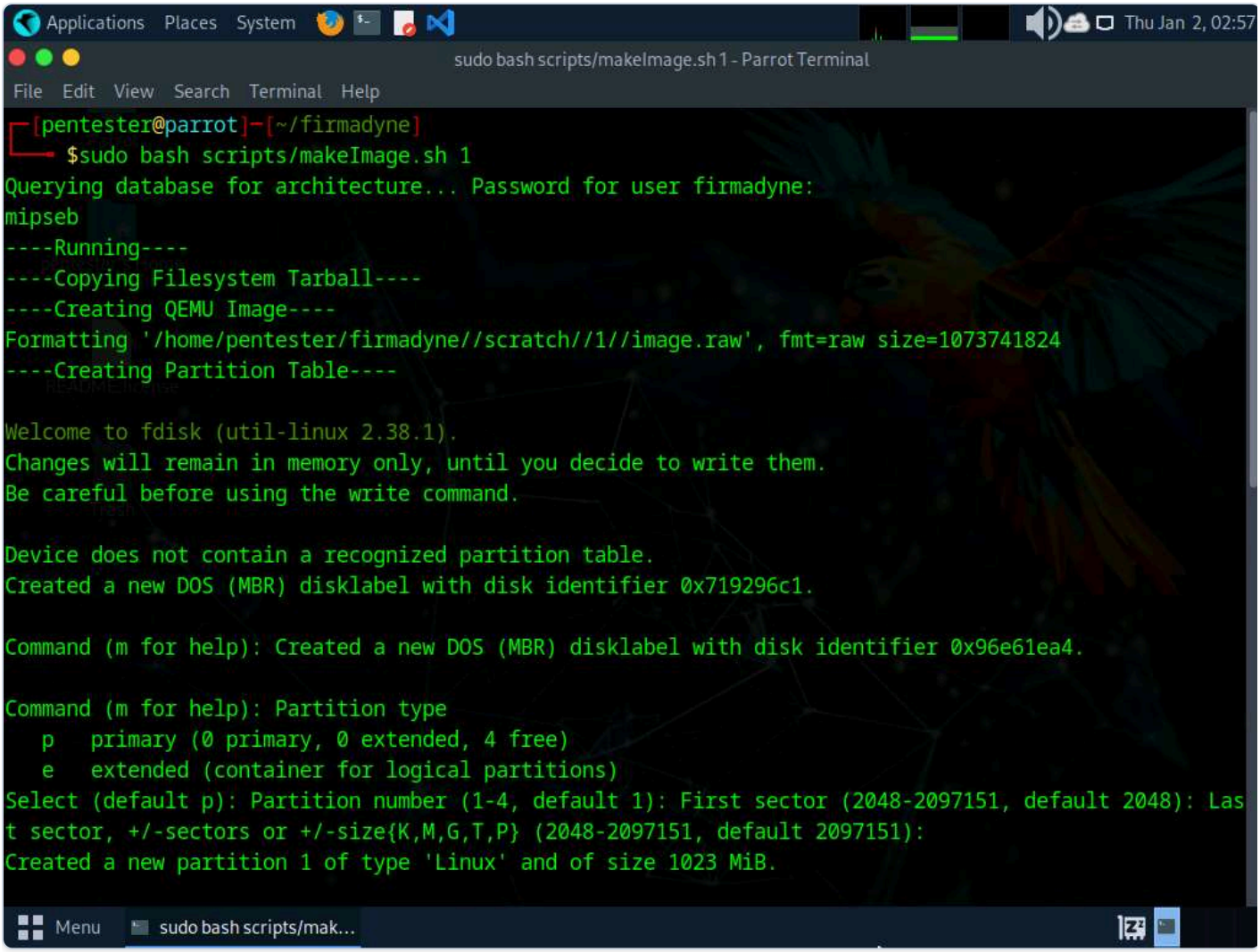



1. Load filesystem metadata into database tables:
   **sudo python3 scripts/tar2db.py -i 1 -f images/1.tar.gz**

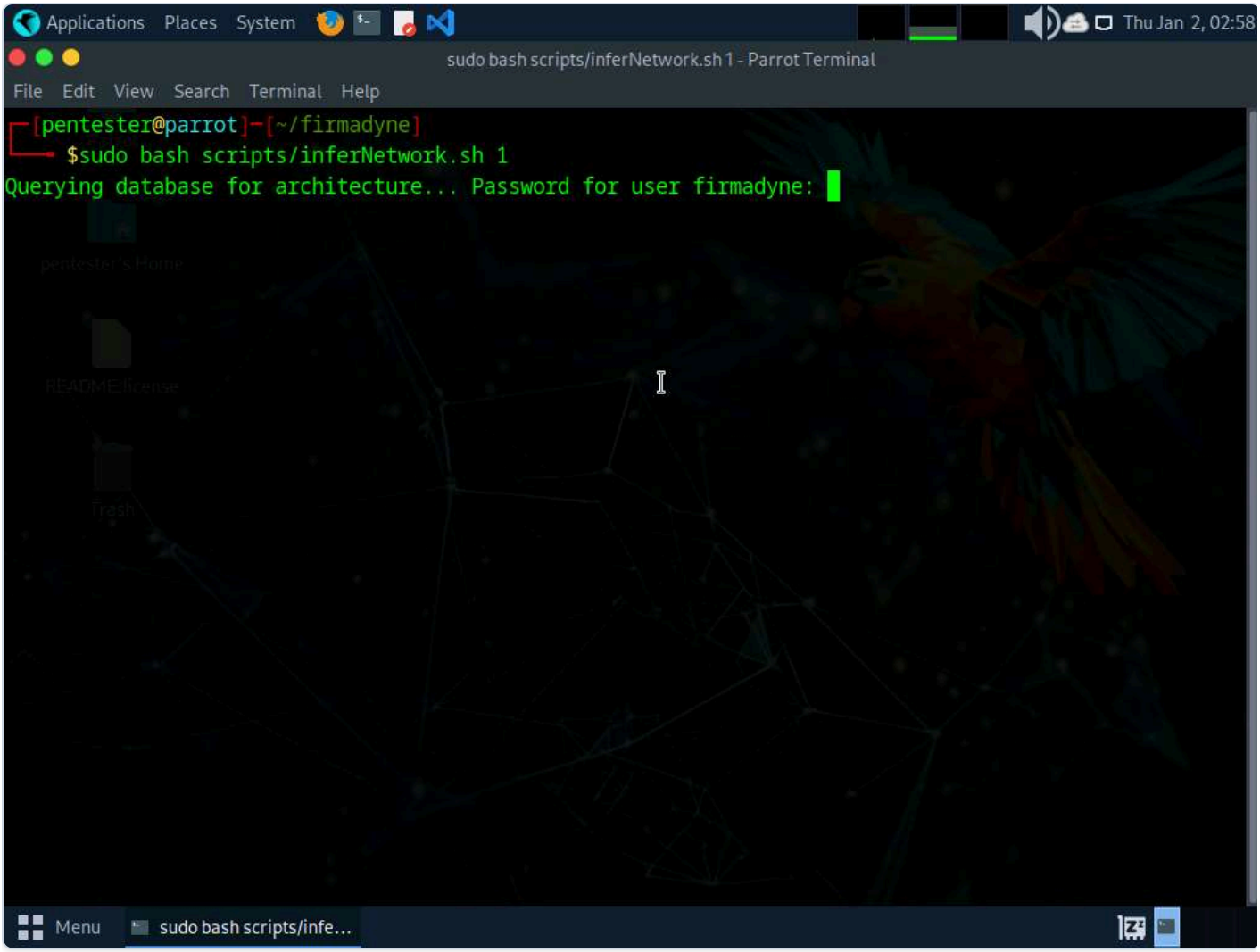


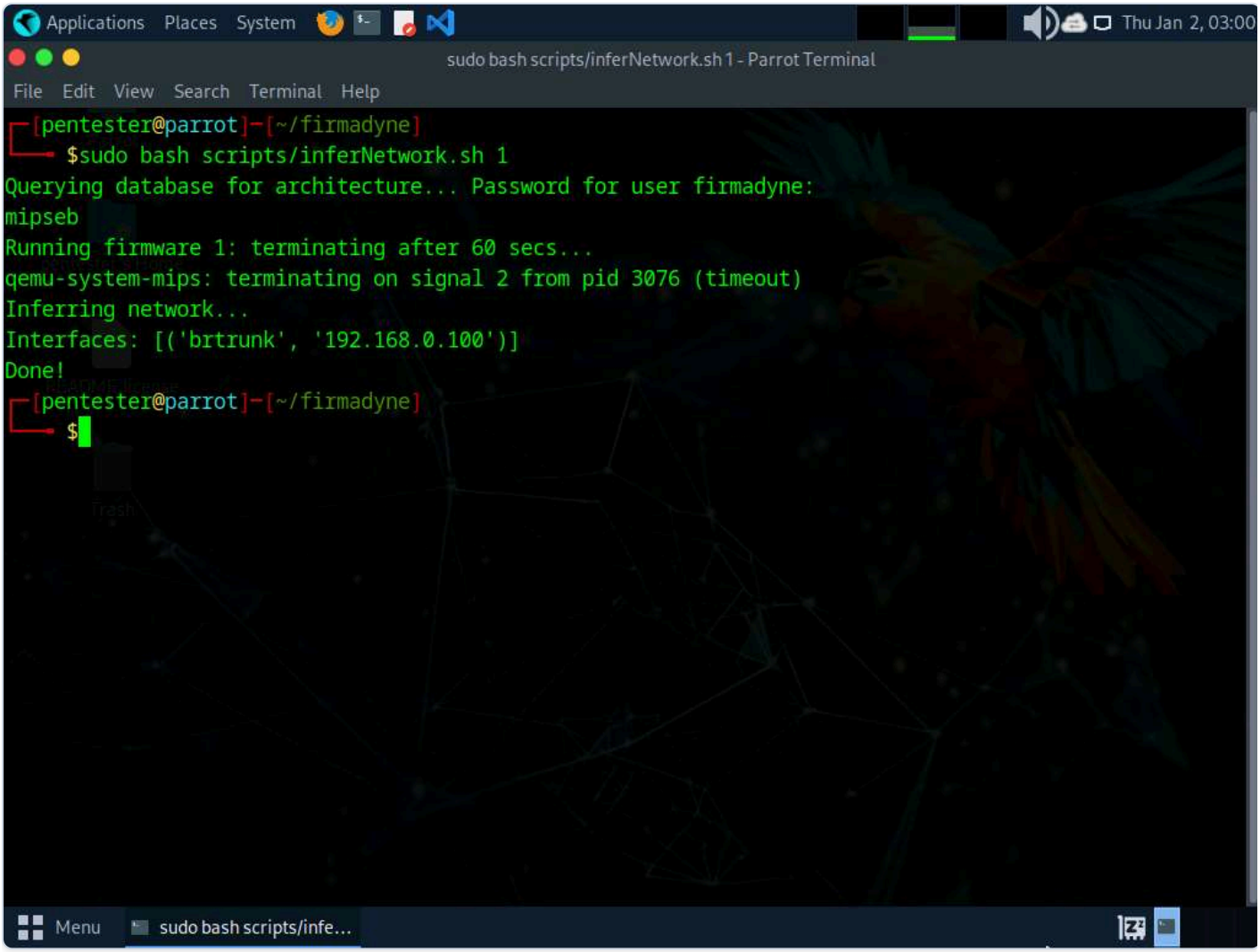

1. Create QEMU raw disk image for firmware ID 1:
   **sudo bash scripts/makeImage.sh 1**


Applications
Places
System
Thu Jan 2, 02:57
sudo bash scripts/makeImage.sh 1 - Parrot Terminal
File
Edit
View
Search
Terminal
Help
[pentester@parrot]-[~/firmadyne]
$sudo bash scripts/makeImage.sh 1
Querying database for architecture... Password for user firmadyne:
pentester's Home
README.license
Trash
Menu
sudo bash scripts/mak...

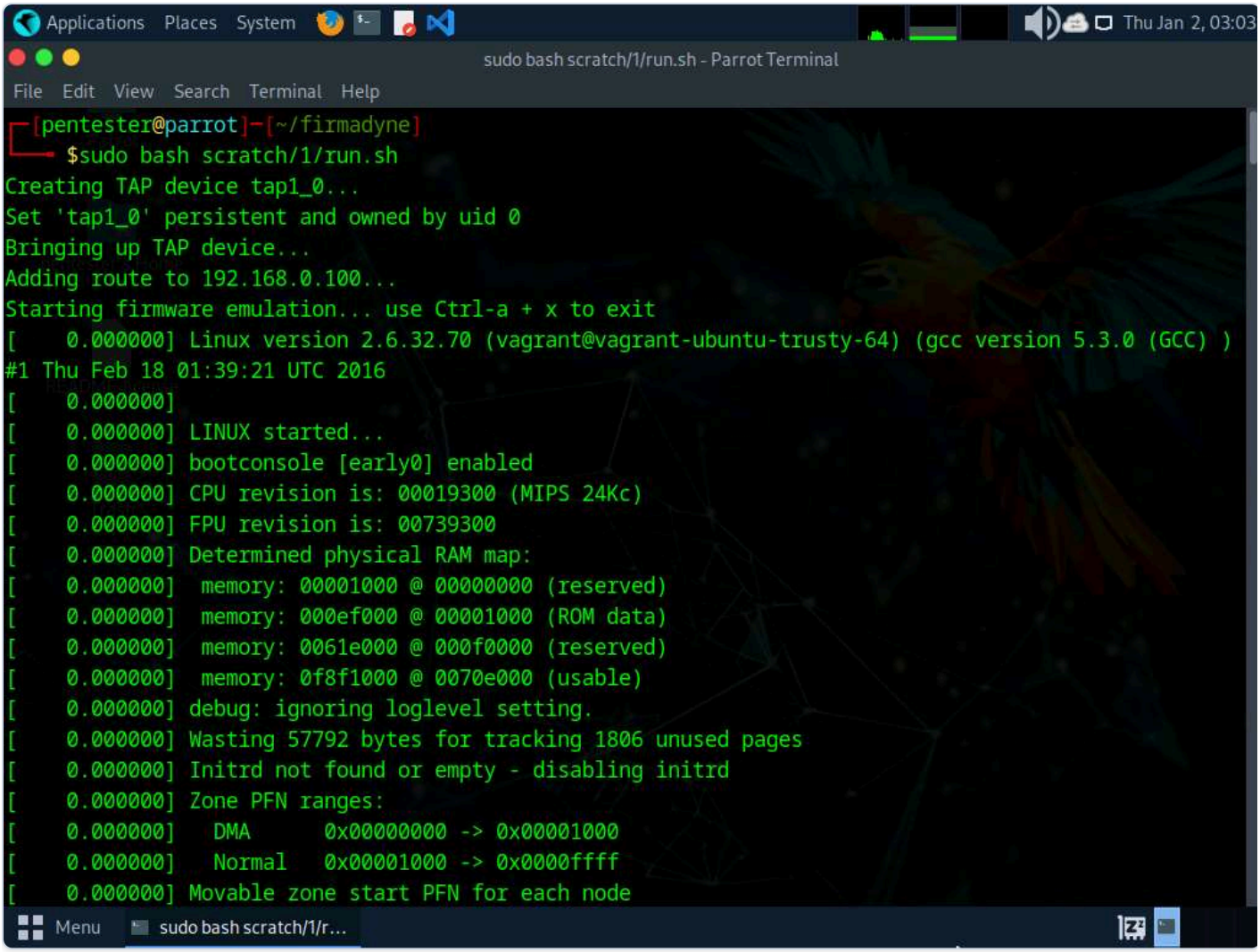


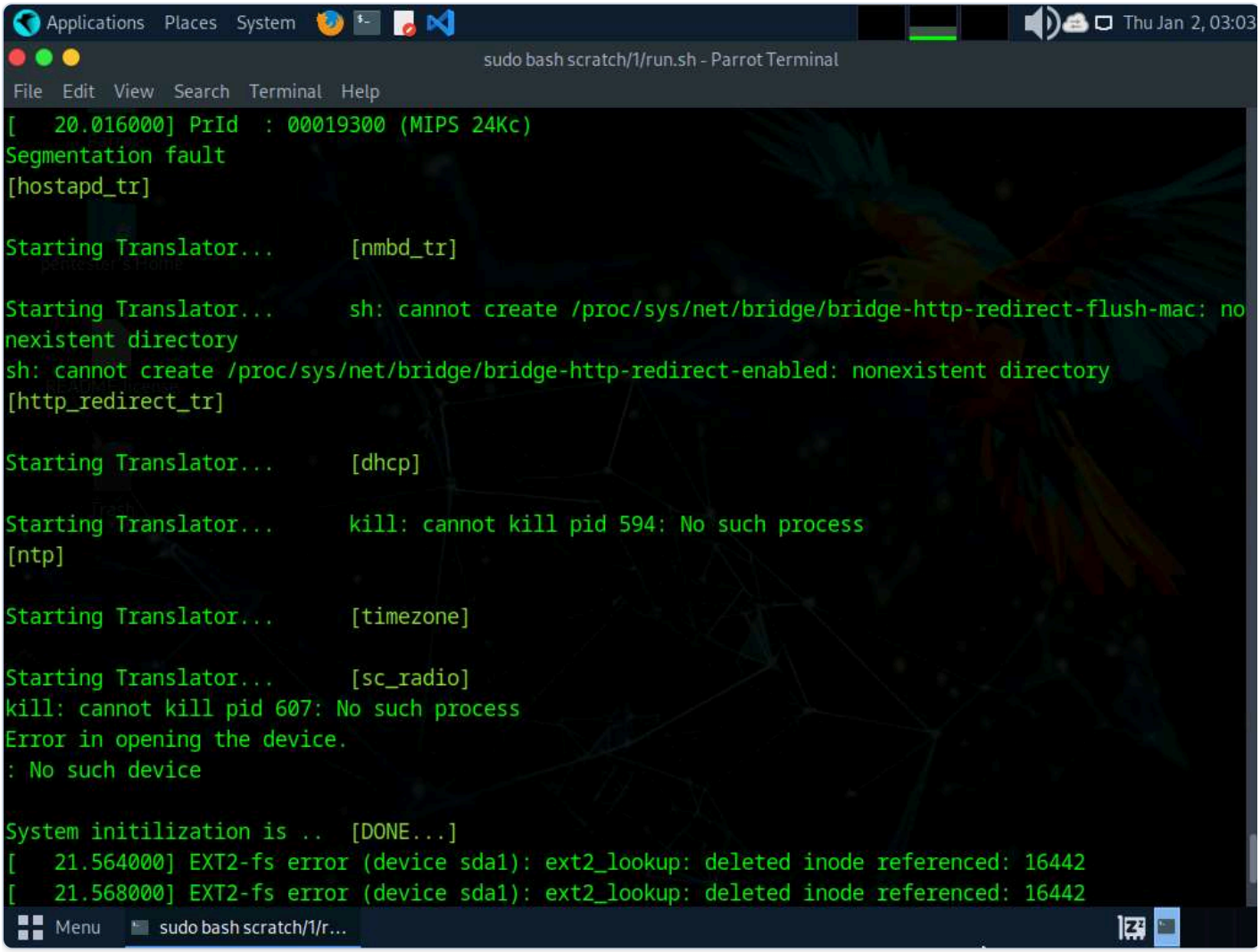

1. Infer network interface and IP routing parameters:
   **sudo bash scripts/inferNetwork.sh 1**


Applications
Places
System
Thu Jan 2, 02:58
sudo bash scripts/inferNetwork.sh 1 - Parrot Terminal
File
Edit
View
Search
Terminal
Help
[pentester@parrot]-[~/firmadyne]
$sudo bash scripts/inferNetwork.sh 1
Querying database for architecture... Password for user firmadyne:
pentester's Home
README.license
Trash
Menu
sudo bash scripts/infe...

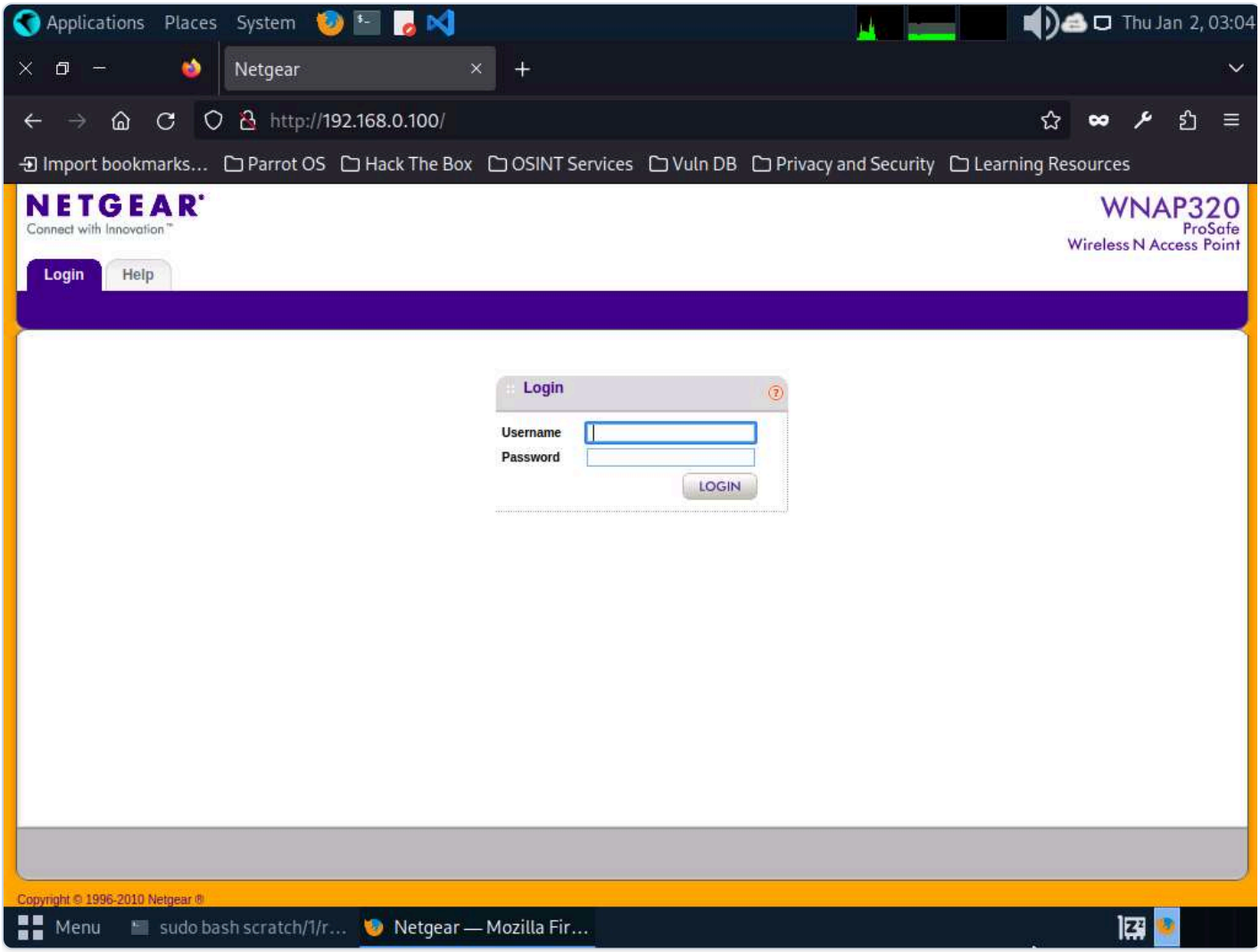



1. Execute QEMU network emulation script:
   **sudo bash scratch/1/run.sh**

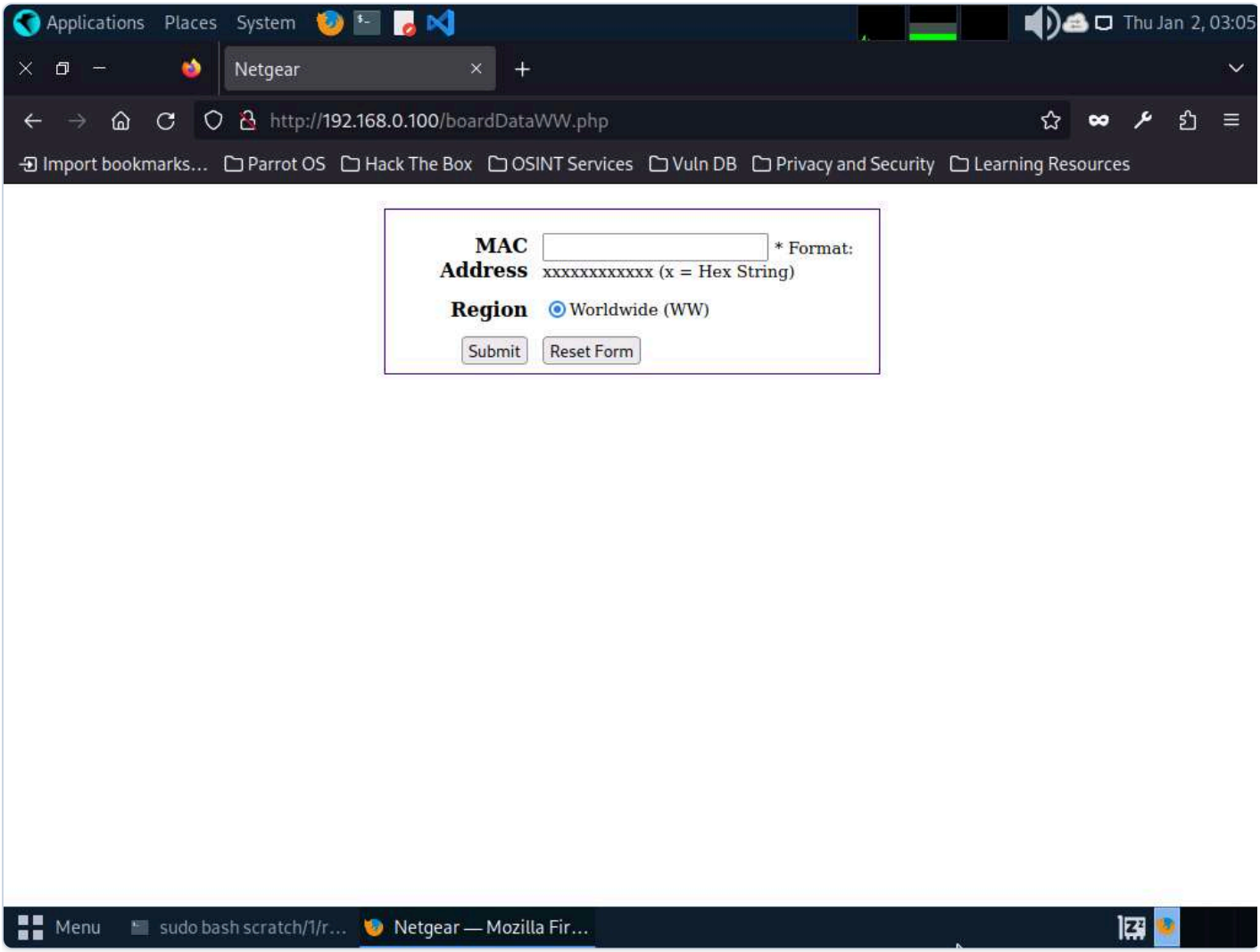

Applications Places System
Thu Jan 2, 03:03
sudo bash scratch/1/run.sh - Parrot Terminal
File Edit View Search Terminal Help
[pentester@parrot]-[~/firmadyne]
$sudo bash scratch/1/run.sh
Creating TAP device tap1_0...
Set 'tap1_0' persistent and owned by uid 0
Bringing up TAP device...
Adding route to 192.168.0.100...
Starting firmware emulation... use Ctrl-a + x to exit
[ 0.000000] Linux version 2.6.32.70 (vagrant@vagrant-ubuntu-trusty-64) (gcc version 5.3.0 (GCC) )
#1 Thu Feb 18 01:39:21 UTC 2016
[ 0.000000]
[ 0.000000] LINUX started...
[ 0.000000] bootconsole [early0] enabled
[ 0.000000] CPU revision is: 00019300 (MIPS 24Kc)
[ 0.000000] FPU revision is: 00739300
[ 0.000000] Determined physical RAM map:
[ 0.000000] memory: 00001000 @ 00000000 (reserved)
[ 0.000000] memory: 000ef000 @ 00001000 (ROM data)
[ 0.000000] memory: 0061e000 @ 000f0000 (reserved)
[ 0.000000] memory: 0f8f1000 @ 0070e000 (usable)
[ 0.000000] debug: ignoring loglevel setting.
[ 0.000000] Wasting 57792 bytes for tracking 1806 unused pages
[ 0.000000] Initrd not found or empty - disabling initrd
[ 0.000000] Zone PFN ranges:
[ 0.000000] DMA 0x00000000 -> 0x00001000
[ 0.000000] Normal 0x00001000 -> 0x0000ffff
[ 0.000000] Movable zone start PFN for each node
Menu
sudo bash scratch/1/r...



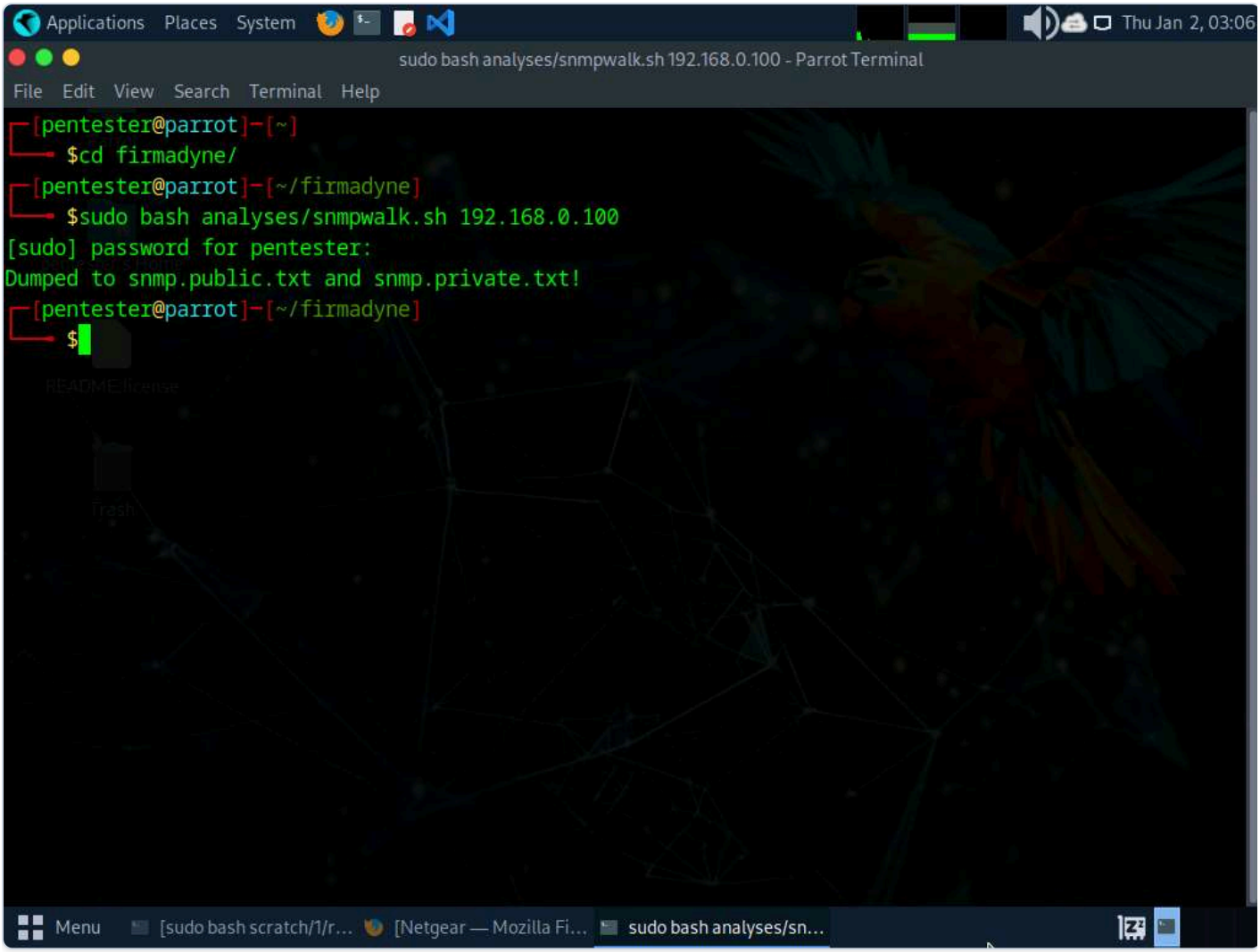

1. Open browser and navigate to emulated WNAP320 web login GUI:
   **http://192.168.0.100**



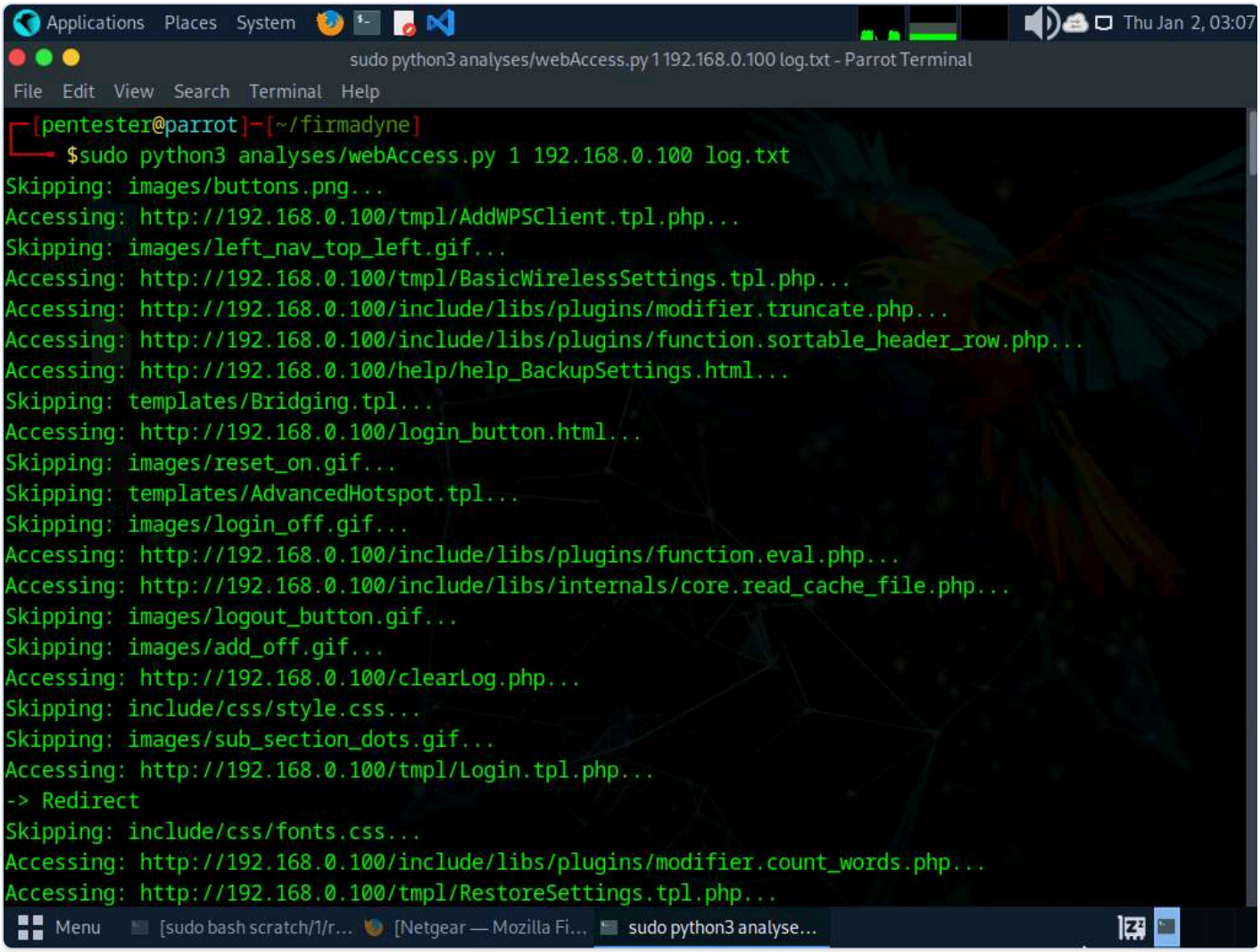

1. Access vulnerable PHP management form in browser:
   **http://192.168.0.100/boardDataWW.php**



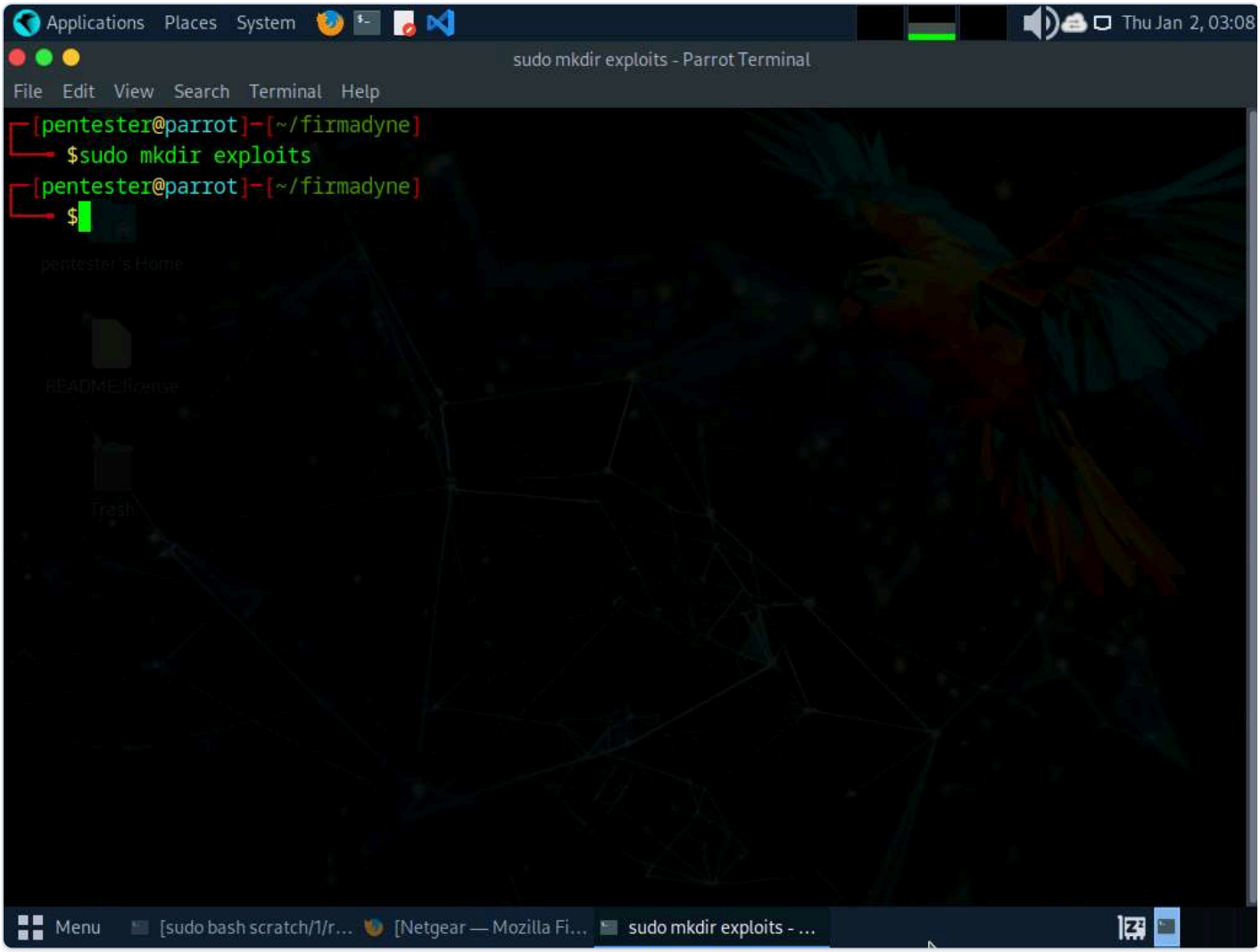

1. Execute SNMP automated enumeration script:
   **sudo bash analyses/snmpwalk.sh 192.168.0.100**

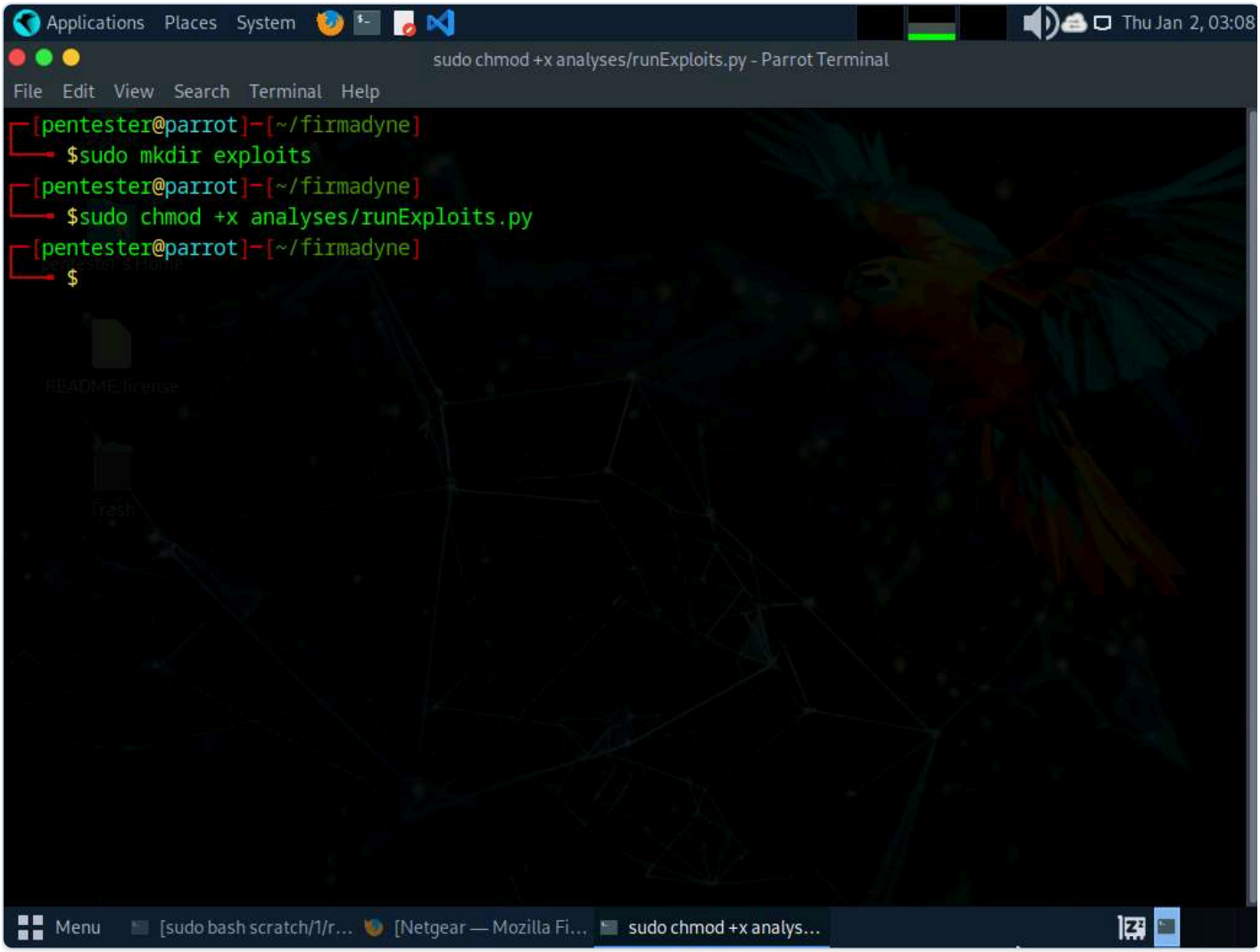



1. Execute web access path analysis script:
   **sudo python3 analyses/webAccess.py 1 192.168.0.100 log.txt**

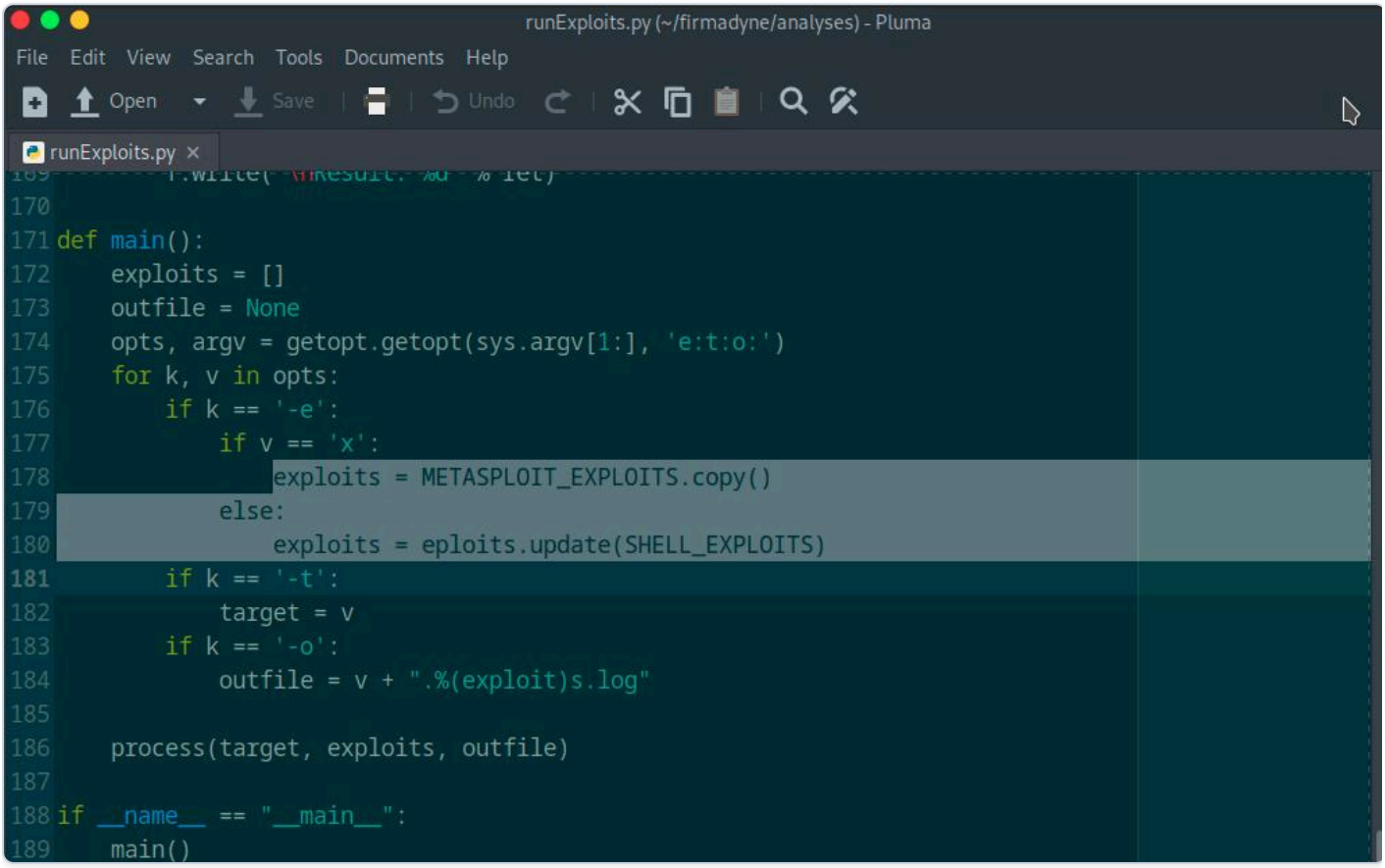



1. Prepare exploits log directory and set executable permissions:
   **sudo mkdir exploits**
   **sudo chmod +x analyses/runExploits.py**


Applications Places System
Thu Jan 2, 03:08
sudo mkdir exploits - Parrot Terminal
File Edit View Search Terminal Help
[pentester@parrot]-[~/firmadyne]
$sudo mkdir exploits
[pentester@parrot]-[~/firmadyne]
$
pentester's Home
README.license
Trash
Menu
[sudo bash scratch/1/r...
[Netgear — Mozilla Fi...
sudo mkdir exploits - ...

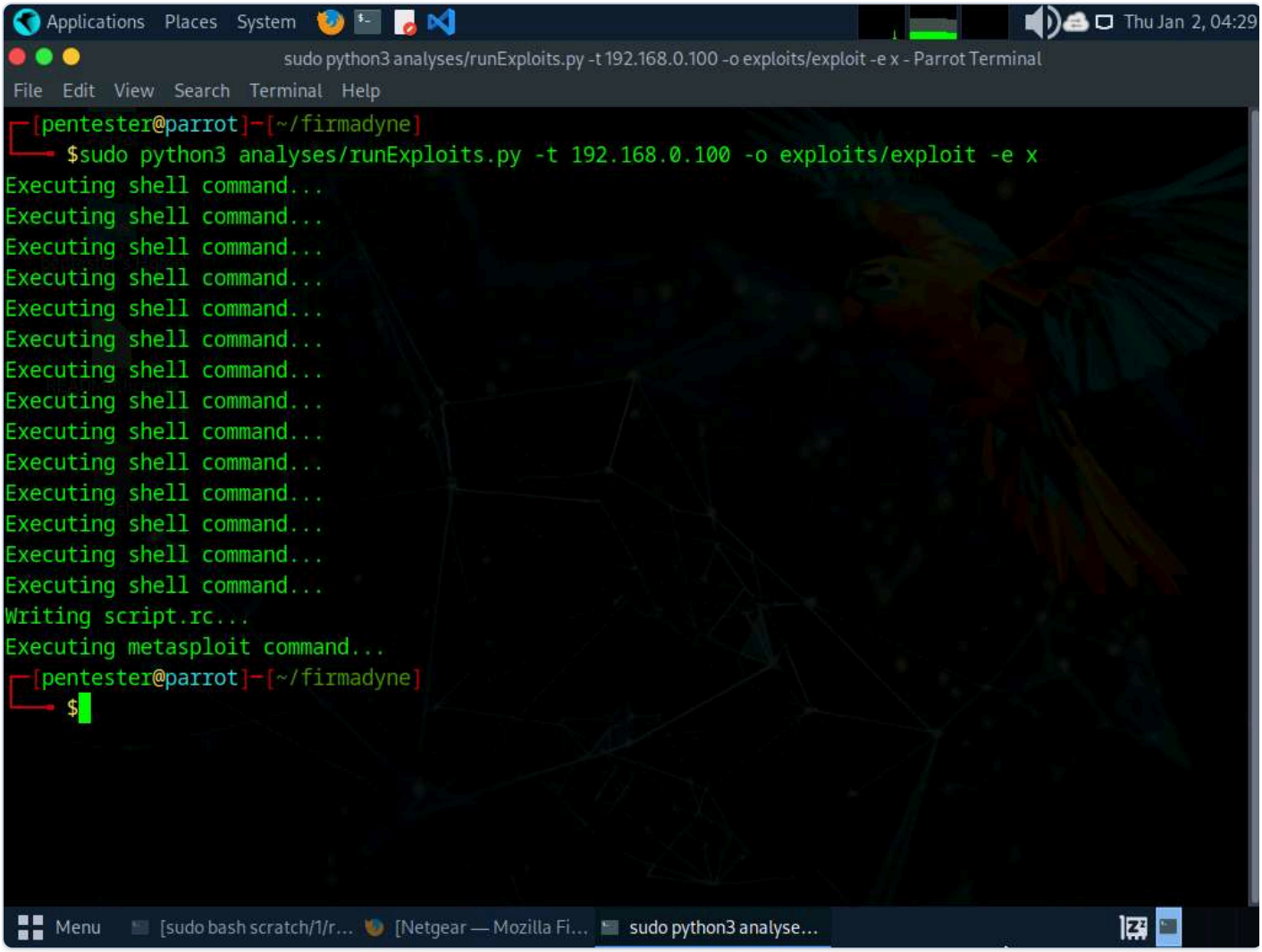



1. Modify `runExploits.py` lines 178 and 180 as required.

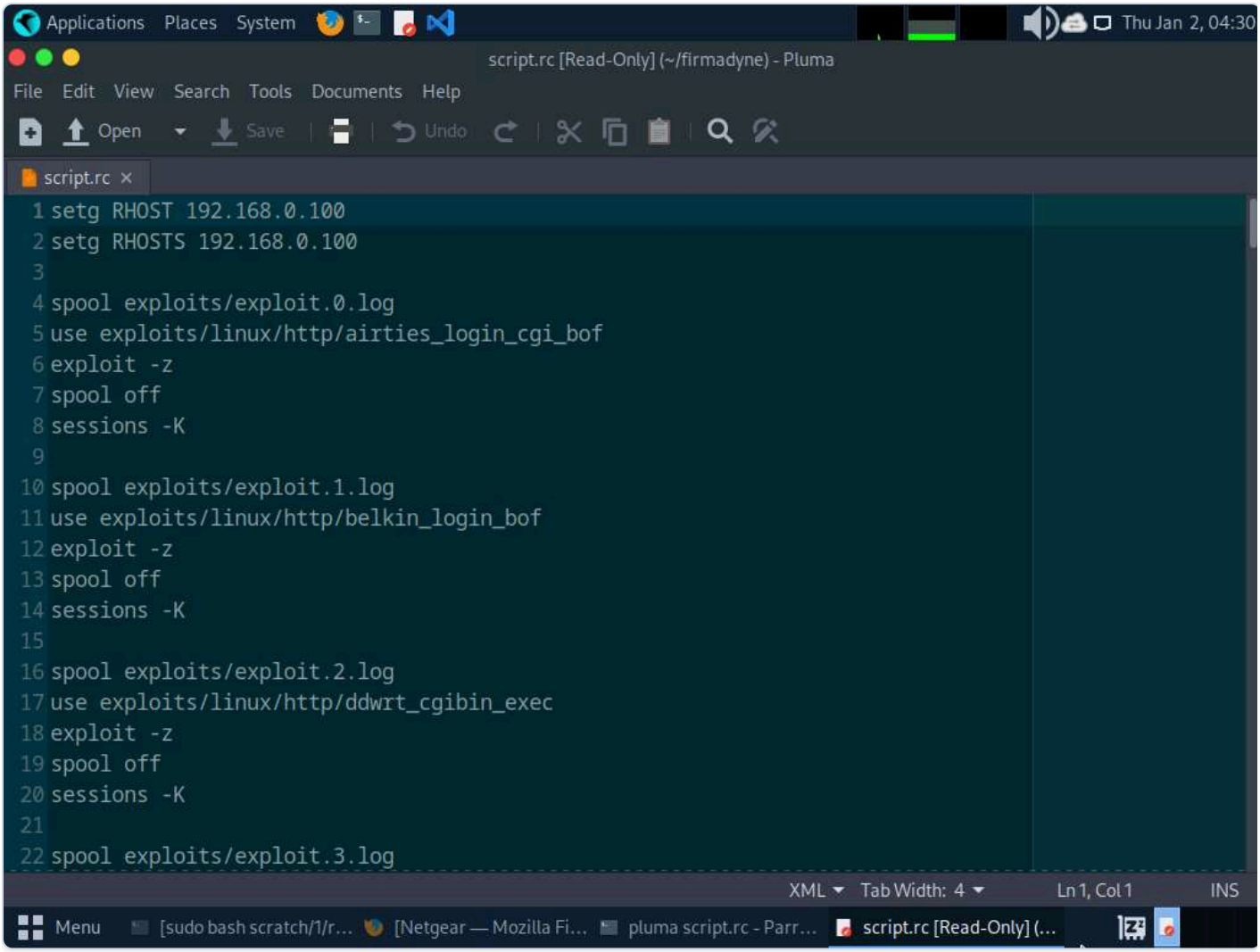


1. Run automated exploit check script:

   **sudo python3 analyses/runExploits.py -t 192.168.0.100 -o exploits/exploit -e x**




1. Inspect generated Metasploit resource script **script.rc** in `/home/pentester/firmadyne`.




This concludes the lab exercise.

---

> **IMPORTANT:** ❓ **Question 13.1.1.1** On the Parrot Security machine, use the sample IoT firmware package (firmware.bin) available at /home/pentester/ in the Parrot machine to identify vulnerabilities and explore the device's file system. Enter the device file system extracted from the sample package. [!SUCCESS] ✅ **Answer:** **squashfs**